Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности
Направление подготовки (специальность) 10.05.03 «Информационная безопасность автоматизированных систем»
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Косухина Богдана Руслановича
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Обнаружение хоста»

Состав выпускной квалификационной работы:
Расчетно-пояснительная записка на 138 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:
Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) (инициалы, фамилия)
Руководитель _____ (Р.С. Лопатин)
(подпись) (инициалы, фамилия)

Консультанты:
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)
по _____ (_____)
(наименование раздела, подпись) (инициалы, фамилия)

Обучающийся _____ Б.Р. Косухин
(подпись) (инициалы, фамилия)
«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет информационных технологий и компьютерной безопасности

Кафедра систем информационной безопасности

Направление подготовки/специальность 10.05.03 «Информационная безопасность автоматизированных систем»
(код, наименование)

Профиль/программа/направленность Обеспечение информационной безопасности распределенных информационных систем

Утверждаю _____
(дата)

Зав.кафедрой _____
(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Косухину Богдану Руслановичу
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Обнаружение хоста»

приказ №01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.25

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы

Глава 1. Анализ баз данных угроз информационной безопасности и риск- калькуляторов
перечень подлежащих разработке в выпускной квалификационной работе вопросов

Глава 2. Определение взаимосвязи между шаблонами атак CAPEC и эксплуатируемыми ими уязвимостями

Глава 3. Формирование сценариев атак заданного шаблона атаки в виде последовательности реализации техник MITRE ATT&CK

Глава 4. Разработка организационно-правовых регламентов, снижающих риски реализации предложенных сценариев атак, заданных шаблонов

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03 – 22.05
2	Анализ баз данных угроз информационной безопасности и риск-калькуляторов	22.03 – 22.05
3	Определение взаимосвязи между шаблонами атак CAPEC и эксплуатируемыми ими уязвимостями	23.05 – 31.05
4	Формирование сценариев атак заданного шаблона атаки в виде последовательности реализации техник MITRE ATT&CK	01.06 – 12.06
5	Разработка организационно-правовых регламентов, снижающих риски реализации предложенных сценариев атак, заданных шаблонов	13.06 – 24.06
6	Заключение	25.06 – 02.07

Руководитель _____
(подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25
(дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающегося Косухина Богдана Руслановича

Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Обнаружения хоста»

Характеристика выпускной квалификационной работы

Актуальность исследования

Исследования определяется стремительным ростом кибератак класса «обнаружение хоста» и отсутствием работ, связанных с оценкой и регулированием рисков успешности данных кибератак.

Задачи, решаемые в ВКР

– организация, сбор открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Обнаружение хоста» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Обнаружение хоста» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Обнаружение хоста» на уязвимости в автоматизированных информационных системах.

Структура ВКР

Введение – 8 страниц

Глава 1. Анализ баз данных угроз информационной безопасности и риск-калькуляторов – 14 страниц.

Глава 2. Определение взаимосвязи между шаблонами атак CAPEC и эксплуатируемыми ими уязвимостями – 11 страниц.

Глава 3. Формирование сценариев атак заданного шаблона атаки в виде последовательности реализации техник MITRE ATT&CK – 62 страниц.

Глава 4. Разработка организационно-правовых регламентов, снижающих риски реализации предложенных сценариев атак, заданных шаблонов – 22 страницы.

Заключение - 2 страницы.

Список литературы – 2 страниц.

Приложение А – 4 страниц.

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Анализ баз данных угроз информационной безопасности и риск-калькуляторов.

Проведен обзор и классификация основных баз данных угроз (CVE, NVD, CAPEC) с выделением критериев полноты, достоверности и актуальности информации для дальнейшего построения микромоделей сценариев атак.

Раздел 2. Определение взаимосвязи между шаблонами атак CAPEC и эксплуатируемыми ими уязвимостями.

Разработана методика сопоставления шаблонов CAPEC с уязвимостями из баз CVE и NVD на основе анализа идентификаторов CWE и семантики описаний.

Раздел 3. Формирование сценариев атак заданного шаблона атаки в виде последовательности реализации техник MITRE ATT&CK.

Разработана методика построения сценариев атак в виде упорядоченных последовательностей техник MITRE ATT&CK для заданных шаблонов CAPEC, позволяющая формировать реалистичные цепочки действий злоумышленника.

Раздел 4. Разработка организационно-правовых регламентов, снижающих риски реализации предложенных сценариев атак, заданных шаблонов.

Разработаны структурированные организационно-правовые регламенты по реагированию на инциденты, включающие этапы обнаружения, уведомления, анализа, локализации и ликвидации последствий атак.

Автор ВКР_____ Косухин Богдан Русланович

(подпись)

СОДЕРЖАНИЕ

Введение 7

1 Анализ баз данных угроз информационной безопасности и риск- калькуляторов. 15

1.1 Анализ баз данных CVE, NVD, CAPEC, БДУ ФСТЭК России и MITRE ATT&CK 15

1.2 Анализ риск-калькуляторов EPSS, CVSS 3.1, CVSS 4.0 и OWASP 19

2 Определение взаимосвязи между шаблонами атак CAPEC и эксплуатируемыми ими уязвимостями 28

3 Формирование сценариев атак заданного шаблона атаки в виде последовательности реализации техник MITRE ATT&CK..... 39

3.1 Оценка критичности эксплуатируемых уязвимостей..... 39

3.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущербов, расчет вероятностей успешного использования уязвимостей и рисков успешности реализации различных вариантов сформированных сценариев атак..... 52

4 Разработка организационно-правовых регламентов, снижающих риски реализации предложенных сценариев атак, заданных шаблонов..... 100

4.1 Разработка организационно-правовых регламентов, для CAPEC – 285..... 101

4.2 Разработка организационно-правовых регламентов, для CAPEC – 295..... 105

4.3 Разработка организационно-правовых регламентов, для CAPEC – 294..... 110

4.4 Разработка организационно-правовых регламентов, для CAPEC – 296..... 115

Заключение..... 121

Список литературы..... 123

Приложение А..... 134

ВВЕДЕНИЕ

Проблема безопасности киберпространства неуклонно возрастает по своей актуальности. Согласно данным за 2024 год:

– 32% всех утечек данных связаны с программами-вымогателями или другими методами вымогательства, при этом медианный ущерб составляет 46 000 долларов США;

– средняя стоимость утечки данных достигла рекордных 4,88 миллиона долларов США, что на 10% больше по сравнению с предыдущим годом;

– в 2024 году мошенники похитили рекордные 27,5 миллиарда рублей (около 300 миллионов долларов США) с банковских счетов в России, что на 74,4% больше по сравнению с предыдущим годом;

– 74% нарушений безопасности включали доступ к привилегированным учетным записям.

В 54% инцидентов ущерб наносился по вине внешних нарушителей, а в 30% — из-за внутренних злоумышленников. В 15% случаев установить источник угроз не удалось.

Однако только 40% крупных компаний имеют отделы, обеспечивающие кибербезопасность, а в 55% компаний за информационную безопасность отвечают IT-службы. При этом 83% компаний хотят перейти на обслуживание во внешний центр мониторинга кибербезопасности.

При таком подходе не приходится надеяться на кардинальные улучшения защищенности киберпространства, и поэтому компаниям предлагаются разнообразные базы данных и калькуляторы, позволяющие самостоятельно оценивать критичность возникающих у них угроз.

Однако разноплановость и неполнота информационных возможностей вышеупомянутого инструментария обуславливают необходимость уточняющих и систематизирующих исследований в этом направлении.

Перечисленные работы ориентированы на различные объекты: предприятия, автоматизированные информационные сети и иные объекты информатизации, а

также сетевое киберпространство в отношении противодействия разнообразным кибератакам, в том числе с использованием средств искусственного интеллекта. Однако общим предметом исследования в них выступают оценка и регулирование рисков, чему, собственно, и посвящена настоящая работа.

Атаки класса «обнаружение хоста», о деструктивном воздействии которых будет поведано в данной работе, занимают важное место в современной киберугрозной среде, поскольку они затрагивают одну из ключевых областей информационной безопасности — управление доступом к ресурсам и данным. Проблема противодействия таким атакам становится особенно актуальной в условиях роста сложности информационных систем и их интеграции в повседневную жизнь, где они обеспечивают работу критически важных сервисов, от автоматизированных информационных сетей до облачных платформ.

По состоянию на 2024 год, количество атак, относящихся к данному классу, не прекращает свой рост. Согласно отчету, Verizon Data Breach Investigations Report за последние годы, злоупотребление привилегиями становится причиной более 15% всех зарегистрированных утечек данных, уступая только фишинговым атакам и уязвимостям программного обеспечения. В период с 2020 по 2024 годы процентное соотношение по увеличению количества атак составляло 19%, 22%, 28% и 34% процента от предыдущего числа атак. Исследования компании CyberArk показывают, что около 80% всех крупных кибератак используют скомпрометированные привилегированные учетные записи для достижения своих целей, будь то эскалация прав доступа, вымогательство или кража данных. Более того, согласно отчету, IBM Cost of a Data Breach, утечки, связанные с неправомерным использованием привилегий, в среднем стоят организациям на 40% дороже, чем инциденты другого характера, из-за масштаба воздействия на системы и данные.

Изложенное выше имеет непосредственное отношение к рассматриваемому в настоящей работе множеству шаблонов кибератак класса «обнаружение хоста». Аналоги, описывающие множество атак данного вида, свидетельствуют о росте активности использования злоумышленниками данного типа атак.

Согласно отчетам компаний, отвечающих за информационную безопасность, за 2024 год атаки типа «обнаружение хоста»:

– являлись одними из наиболее эффективных видов атак, превзойдя показатели 2023 года на 39%;

– основными целями для атак подобного рода становились предприятия финтеха, здравоохранения и управления воздушным транспортом;

– наиболее явной уязвимостью, выделившейся при осуществлении данных атак, стала CVE-2024-44228, замеченная в библиотеке данных компании Amazon;

– основными мотивами для совершения преступлений, в которых использовались данные атаки, являлось вымогательство денежных средств, личная обида и убежденность в неправоте нанимателя;

– аналитические прогнозы относительно применения атак данного вида прогнозируют увеличение активности в ближайшие годы минимум на 27%.

Рост числа объектов атаки, важность атакуемых объектов для массового пользователя и интерес нарушителей к атакам типа «обнаружение хоста» свидетельствуют о том, что проблема обеспечения безопасности автоматизированных информационных систем (АИС) от данного типа атак не только сохраняет свою актуальность, но и усиливает её значимость по результатам статистики за прошедший 2024 год.

Тем не менее, методическое обеспечение для оценки опасности атак класса «обнаружение хоста», представленное в существующих источниках, не соответствует в полной мере современным требованиям кибербезопасности, что вызывает множество вопросов относительно его практической применимости. Действующие методики недостаточно охватывают вероятностные модели реализации угроз, не отражают всей полноты возможных техник, применяемых злоумышленником, и не дают возможности построения точных сценариев развития атаки.

В большинстве случаев аналогичные работы не используют матрицу MITRE ATT&CK в качестве базы для оценки угроз, в результате чего специалисты не могут полноценно оценить этапность кибератак, их глубину проникновения и потенциальную критичность в зависимости от объекта воздействия. Особенно остро

стоит вопрос об отсутствии интеграции современных риск-калькуляторов и адаптированных коэффициентов критичности, что значительно снижает практическую эффективность предлагаемых в аналогах мер защиты.

В данной работе предлагается комплексный подход к оценке успешности реализации атак класса «обнаружение хоста» в АИС, основанный на подробной классификации техник атак, применении адаптированных вероятностных моделей и использовании актуальных риск-калькуляторов.

Важной особенностью предлагаемой методики является её ориентированность на практическое применение в рамках корпоративных систем, где АИС играют критически важную роль. Дополнительно в исследовании приводится набор нормативно-правовых рекомендаций, направленных на стандартизацию процедур реагирования и ликвидации последствий атак рассматриваемого класса. Это обеспечит компаниям не только средства оценки рисков, но и инструменты для стратегического и оперативного управления инцидентами информационной безопасности.

Таким образом, настоящее исследование направлено на разработку и обоснование эффективной системы оценки и регулирования рисков успешности реализации кибератак класса «обнаружение хоста» в АИС, что делает его актуальным и значимым вкладом в современную теорию и практику кибербезопасности.

Объектом исследования выступают автоматизированные информационные системы, подвергающиеся атакам класса «Обнаружение хоста».

Предметом исследования процессы обеспечения информационной безопасности автоматизированных информационных систем при воздействии кибератак класса «Обнаружение хоста», включающие анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования состоит в повышении защищенности автоматизированных информационных систем от атак класса «Обнаружение хоста».

Исследование аналогов показало наличие ряда **противоречий** между:

– необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака - уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Обнаружение хоста»;

– потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

– существующей методологией вероятностной оценки опасности кибератак класса «Обнаружение хоста» использующей калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

– несовершенством процедур регламентации противодействия кибератакам класса «Обнаружение хоста» и необходимостью осуществлять такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие **задачи**:

– организация, сбор открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Обнаружение хоста» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Обнаружение хоста» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Обнаружение хоста» на уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

– структурированы база данных кибератак класса «Обнаружение хоста» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

– векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

– методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Обнаружение хоста», с учётом специфики используемых злоумышленников сценариев;

– комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Обнаружение хоста» на уязвимости АИС.

Новизна полученных результатов состоит в следующем:

– в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализации класса кибератак «Обнаружение хоста», используемых в автоматизированных информационных системах, что обеспечивает основу для комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

– впервые для класса кибератак «Обнаружение хоста» была предложены обобщённая графическая модель сценариев атак, которые могут быть использованы злоумышленником для вторжения в АИС;

– в отличии от аналогов предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Обнаружение хоста», а также определены наиболее вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

– для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Обнаружение хоста».

Практическая ценность полученных результатов видится в том, что:

– созданная база данных метрик кибератак класса «Обнаружение хоста» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

– сформированное множество сценариев и их рисканализ отражает практику реализации проектной деятельности защиты АИС от атак класса «Обнаружение хоста»;

– предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Обнаружение хоста», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

– предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Обнаружение хоста» на защищаемые АИС.

Теоретическая значимость полученных результатов видится в том, что:

– сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

– разработанные сценарии атак класса «Обнаружение хоста» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

– представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Обнаружение хоста», могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

– в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Обнаружение хоста» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1 Анализ баз данных угроз информационной безопасности и риск-калькуляторов

1.1 Анализ баз данных CVE, NVD, CAPEC, БДУ ФСТЭК России и MITRE ATT&CK

Нынешняя цифровая эпоха требует новых подходов к защите информации, поскольку количество и сложность кибератак растут экспоненциально, а методы злоумышленников становятся все более изощренными. В этих условиях традиционные системы обнаружения угроз и управления инцидентами уже не могут ограничиваться внутренними ресурсами и стандартными методами анализа – им необходимы актуальные и надежные внешние источники знаний. Ключевую роль здесь играют специализированные базы данных угроз и уязвимостей, такие как CAPEC, MITRE ATT&CK, NVD и БДУ ФСТЭК России, которые содержат структурированную информацию о типах атак, тактиках злоумышленников и конкретных уязвимостях программного обеспечения. Эти базы данных можно рассматривать как "коллективную память" специалистов по кибербезопасности, систематизирующую знания о существующих угрозах, механизмах их работы и способах противодействия.

Сегодня информационная безопасность постепенно отходит от медотов, которые основаны на устранении последствий прошедших инцидентов к подходу, где предугадываются действия злоумышленников. Поэтому базы данных угроз помогают решать критически важные задачи:

- оперативное обнаружение кибератак, так как системы типа SIEM (Security Information and Event Management) и EDR (Endpoint Detection and Response) хранят информацию о текущих инцидентов с известными угрозами;
- предоставление информации о новых уязвимостях, что позволяет обнаружить новые точки проникновения, своевременно обновить ПО и устранить уязвимые места;
- проведение оценки рисков, что помогает спрогнозировать вероятность и последствия возможных атак.

Среди наиболее значимых баз данных особое место занимает CAPEC (Catalog of Attack Patterns), разработанная MITRE. В отличие от стандартных списков уязвимостей, фокусирующихся на технических аспектах систем, CAPEC предлагает более широкий взгляд на процесс атак, документируя не просто отдельные уязвимости, а целостные схемы атак, охватывающие все этапы – от разведки до исполнения. Каждая запись в CAPEC детально описывает определенный атакующий паттерн, включая его цель, механизм работы и возможные способы защиты, а также содержит метки, указывающие на степень сложности реализации атаки. Такой подход позволяет специалистам по информационной безопасности не только лучше понять, как злоумышленники могут использовать уязвимости, но и разрабатывать более эффективные методы защиты. Также имеет возможность интегрировать данные с другими базами для более детального анализа угроз, например, MITRE ATT&CK.

MITRE ATT&CK является не менее важной базой данных, где описываются тактики и техники, которые наиболее часто используют злоумышленники. Там подробно описываются действия злоумышленников на каждом шаге проведения атаки. Если сравнивать сведения баз данных, MITRE ATT&CK основана на реальных инцидентах, что позволяет точно анализировать действия нарушителей. Открытость и бесплатный доступ к этой базе данных способствуют ее широкому распространению среди исследователей и специалистов по безопасности, а возможность интеграции с другими инструментами значительно облегчает ее применение на практике. Использование ATT&CK позволяет не только анализировать уже произошедшие атаки, но и разрабатывать стратегии для предотвращения будущих угроз, обеспечивая раннее обнаружение подозрительной активности, мониторинг атак в реальном времени, создание более точных средств защиты и обучение специалистов.

Для работы с конкретными уязвимостями незаменима NVD (National Vulnerability Database) – централизованная база данных, поддерживаемая Национальным институтом стандартов и технологий США (NIST). В отличие от CAPEC и ATT&CK, NVD ориентирована именно на систематизацию уязвимостей в программном обеспечении, предоставляя подробные описания, рекомендации по исправлению и оценку серьезности каждой уязвимости через систему CVSS (Common

Vulnerability Scoring System). Эта база данных тесно интегрируется с другими ресурсами, включая MITRE ATT&CK и CAPEC, а также с системами управления уязвимостями и SIEM-решениями, что позволяет специалистам по безопасности оперативно выявлять критические уязвимости в системах и принимать соответствующие меры. NVD играет ключевую роль в поддержке стандарта CVE (Common Vulnerabilities and Exposures), обеспечивая идентификацию и классификацию уязвимостей, и служит важным источником информации для оценки рисков и разработки стратегий защиты.

Для российских организаций особое значение имеет БДУ ФСТЭК России – национальная база данных уязвимостей и угроз информационной безопасности, разработанная Федеральной службой по техническому и экспортному контролю. БДУ ФСТЭК России соответствует российским требованиям и стандартам безопасности, что позволяет охватить полный диапазон аспектов не только уязвимостей, но и угроз. Эта база данных так же имеет возможность интеграции с международными стандартами и базами данных в области информационной безопасности.

Несмотря на различия в подходах и фокусировке, все четыре рассмотренные базы данных – CAPEC, MITRE ATT&CK, NVD и БДУ ФСТЭК – преследуют общую цель повышения уровня информационной безопасности и могут эффективно использоваться в комбинации. CAPEC обеспечивает понимание методов атак в широком контексте, MITRE ATT&CK предоставляет детализированную информацию о поведении злоумышленников, NVD фокусируется на конкретных уязвимостях и способах их устранения, а БДУ ФСТЭК адаптирует эти знания к российским реалиям и нормативным требованиям. Совместное использование этих ресурсов позволяет создавать комплексные стратегии защиты, сочетающие проактивный подход к предотвращению атак, глубокий анализ угроз и строгое соответствие регуляторным требованиям, что особенно важно в условиях постоянно evolving cyber threat landscape.

Современные системы оценки уязвимостей представляют собой комплексный инструментарий для анализа и приоритизации киберугроз. Наиболее распространённой и признанной методикой является Common Vulnerability Scoring System (CVSS), текущая версия 3.1 которой включает три группы взаимосвязанных

метрик. Базовые метрики отражают фундаментальные характеристики уязвимости, включая эксплуатационные параметры (такие как вектор атаки, сложность эксплуатации и требуемые привилегии) и показатели воздействия (влияние на конфиденциальность, целостность и доступность данных). Эти показатели формируют базовый балл от 0.0 до 10.0 с градацией по уровням критичности. Временные метрики добавляют динамический компонент оценки, учитывающий появление эксплойтов, доступность патчей и достоверность информации об уязвимости. Контекстные метрики позволяют адаптировать оценку под конкретную ИТ-инфраструктуру, принимая во внимание особенности защищаемой среды и бизнес-значимость потенциально уязвимых активов.

Однако CVSS 3.1 имеет ряд ограничений, которые устраняет новая версия CVSS 4.0, введшая важные усовершенствования: более детализированную систему метрик, чёткое разделение понятий тяжести уязвимости и риска её эксплуатации, а также улучшенные механизмы учёта контекстных факторов. Эти изменения позволяют проводить более точную и релевантную оценку современных киберугроз.

Для прогнозирования вероятности эксплуатации уязвимостей был разработан Exploit Prediction Scoring System (EPSS), который использует статистические модели и машинное обучение для анализа исторических данных об атаках. В отличие от CVSS, оценивающего потенциальную опасность уязвимости, EPSS прогнозирует вероятность её реального использования злоумышленниками в ближайшие 30 дней. Этот подход особенно ценен для приоритизации исправлений, позволяя сосредоточиться на наиболее вероятных векторах атаки.

В контексте веб-приложений широкое применение находит OWASP Risk Rating Methodology, которая учитывает, как технические параметры уязвимостей (вероятность эксплуатации и потенциальный ущерб), так и бизнес-факторы (критичность затронутых данных и систем). Хотя эта методика менее формализована по сравнению с CVSS, она обеспечивает быструю и наглядную оценку рисков, особенно полезную на этапах разработки и тестирования приложений.

Современные практики кибербезопасности рекомендуют комплексное использование этих методик: CVSS для базовой оценки тяжести уязвимостей, EPSS

для прогнозирования актуальных угроз и OWASP Risk Rating для анализа рисков в контексте конкретных бизнес-процессов. Такой многоуровневый подход позволяет организациям оптимизировать ресурсы безопасности, своевременно устраняя наиболее опасные уязвимости и эффективно противодействуя современным киберугрозам. Интеграция этих систем в единый процесс управления уязвимостями становится ключевым элементом стратегий кибербезопасности, обеспечивающим баланс между полнотой защиты и экономической эффективностью. В таблице 1 ниже проведен сравнительный анализ баз данных.

Таблица 1 – Сравнительный анализ баз данных

Параметр	CAPEC	MITRE ATT&CK	NVD	БДУ ФСТЭК
Тип данных	Шаблоны атак	Техники атак	Уязвимости	Уязвимости
Подход	Превентивный	Реактивный	Реактивный	Реактивный
Основная цель	Проектирование	Реагирование	Управление рисками	Соответствие
Уровень детализации	Высокий	Высокий	Средний	Средний

При объединении этих баз данных, картина рисков и угроз становится гораздо полнее. Это помогает специалистам по информационной безопасности видеть всю ситуацию целиком, находить слабые места и принимать более обоснованные решения. Данные из разных источников дополняют друг друга, делая защиту систем продуманной и эффективной.

1.2 Анализ риск-калькуляторов EPSS, CVSS 3.1, CVSS 4.0 и OWASP

Основу безопасности составляют управление уязвимостями и грамотная оценка рисков. Но как понять, на какие угрозы реагировать в первую очередь? И как определить уровень опасности той или иной уязвимости?

Здесь на помощь приходят специальные инструменты — риск-калькуляторы, такие как CVSS, EPSS и OWASP Risk Rating Methodology. Они автоматизируют оценку потенциального ущерба и помогают распределить ресурсы на устранение самых критичных проблем.

Раньше такие расчёты делали вручную, что было долго и не всегда точно. Сейчас же специалисты по информационной безопасности могут анализировать сотни уязвимостей за считанные минуты. Давайте разберём, как работают самые эффективные из этих инструментов.

CVSS (Common Vulnerability Scoring System) — это универсальная система, предназначенная для количественной оценки уязвимостей информационных систем. Она позволяет определить, насколько серьёзной является та или иная уязвимость. Стандарт разработан форумом FIRST (Forum of Incident Response and Security Teams).

CVSS 3.1 включает три основные группы метрик:

1) базовая метрика (Base Metrics) — отражает основные характеристики уязвимости;

2) временная метрика (Temporal Metrics) — показывает, как меняется степень опасности уязвимости со временем;

3) контекстная метрика (Environmental Metrics) — учитывает специфику конкретной среды.

Базовые метрики определяют внутренние свойства уязвимости. Эти параметры не изменяются со временем и не зависят от конкретной организации.

Базовые метрики подразделяются на два типа:

1) характеристики эксплуатации (Exploitability) — отвечают на вопрос о том, насколько легко злоумышленнику использовать уязвимость;

2) влияние на систему (Impact) — оценивают потенциальный ущерб, который может быть нанесён системе при успешном использовании уязвимости.

В результате базовая оценка CVSS 3.1 может находиться в следующих диапазонах: 0.0 (не критично), 0.1–3.9 (низкая степень критичности), 4.0–6.9 (средняя степень критичности), 7.0–8.9 (высокая степень критичности), 9.0–10.0 (критическая уязвимость).

Временные метрики учитывают изменения в течение времени, например, появление эксплойтов или патчей. Они включают [24]:

1) уровень зрелости эксплойта (exploit code maturity);
2) уровень исправления (remediation level);
3) уверенность в сообщении (report confidence).

Контекстные метрики позволяют учесть особенности конкретной компании. Одна и та же уязвимость может быть критичной для банка, но менее значимой для маленькой интернет-компании. Основными факторами являются:

Изменённое влияние (modified Impact) — конфиденциальность, целостность, доступность для конкретной организации;

Требования к безопасности (security requirements) — насколько важна защита определённых данных для компании.

Однако, CVSS 3.1 начала утрачивать свою актуальность из-за выхода новой версии — CVSS 4.0. Эта версия внесла ряд улучшений, таких как повышение контекстности (теперь учитываются текущие угрозы и эксплуатационные факторы), улучшенная гибкость (добавлены новые метрики, делающие систему более адаптивной к различным сценариям) и разделение тяжести уязвимости и риска её использования (CVSS 4.0 различает "severity" (тяжесть) и "risk" (риск)).

Базовые метрики в новой версии претерпели значительные изменения, что подтверждается информацией из табл. 2 ниже

Таблица 2 – Изменения базовых метрик

Метрика	Значения	Описание
Вектор атаки (AV)	Network (N), Adjacent (A), Local (L), Physical (P)	Указывает, откуда можно эксплуатировать уязвимость
Сложность атаки (AC)	Low (L), High (H)	Показывает, насколько сложно эксплуатировать уязвимость
Требования к привилегиям (PR)	None (N), Low (L), High (H)	Указывает, какие права нужны атакующему
Взаимодействие пользователя (UI)	None (N), Required (R)	Требуется ли действие пользователя для атаки

Продолжение таблицы 2

Метрика	Значения	Описание
Область воздействия (S)	Unchanged (U), Changed (C)	Указывает, изменяется ли область воздействия
Воздействие на конфиденциальность (C)	None (N), Low (L), High (H)	Оценивает, как нарушается конфиденциальность данных
Воздействие на целостность (I)	None (N), Low (L), High (H)	Показывает, может ли злоумышленник изменить данные
Воздействие на доступность (A)	None (N), Low (L), High (H)	Показывает, влияет ли атака на доступность системы

Метрики угроз позволяют оценить вероятность и последствия эксплуатации уязвимости в реальном времени. Они помогают определять приоритеты по исправлению уязвимостей, учитывая текущие атакующие факторы. Эти метрики являются нововведением в версии CVSS 4.0 и обеспечивают более точное различение понятий «тяжесть» и «риск», что представлено в таблице 3.

Таблица 3 – Метрика угроз

Метрика	Значения	Описание
EPSS (Exploit Prediction Scoring System)	0-100 (в процентах)	Вероятность того, что уязвимость будет эксплуатирована
Активная эксплуатация (Active Exploitation, AE)	Yes (Y), No (N)	Показывает, используется ли уязвимость в реальных атаках
Текущие эксплойты (Current Exploit Availability, CEA)	Yes (Y), No (N)	Указывает, существуют ли публично доступные эксплойты
Активность злоумышленников (Adversary Activity, AA)	High (H), Medium (M), Low (L)	Оценивает активность атакующих, связанных с уязвимостью

Данные метрики принимают во внимание особенность определенной среды, где развернута автоматизированная информационная система. Где для одной компании уязвимость является критической, а в другой - менее важной, что позволяет определить её приоритет. Информация о характеристиках метрик представлены ниже в таблице 4.

Таблица 4 – Метрики окружения

Метрика	Значения	Описание
Область воздействия (S)	Changed (C), Unchanged (U)	Изменяется ли область воздействия при эксплуатации
Конфиденциальность (C)	None (N), Low (L), High (H)	Влияет ли уязвимость на конфиденциальность данных в организации
Целостность (I)	None (N), Low (L), High (H)	Влияет ли уязвимость на целостность критических данных
Доступность (A)	None (N), Low (L), High (H)	Влияет ли уязвимость на доступность системы

Дополнительные метрики, в свою очередь, включают в себя ряд значений, которые не входят в основную схему оценки, однако их так же можно использовать в целях анализа. Их описание обозначено в таблице 5 ниже.

Таблица 5 – Дополнительные метрики

Метрика	Значения	Описание
Отчёт об уязвимости (Vulnerability Report, VR)	Open, Closed	Показывает, открыт ли отчёт об уязвимости
Публичное раскрытие (Public Disclosure, PD)	Yes (Y), No (N)	Указывает, известна ли уязвимость публично
Критичность бизнеса (Business Criticality, BC)	Low (L), Medium (M), High (H)	Показывает, как сильно уязвимость влияет на бизнес

Система оценки представляет риск-калькулятор EPSS (Exploit Prediction Scoring System), который направлен на прогнозирование использования уязвимости. Риск-калькулятор был создан для понимания вероятности, насколько выявленная уязвимость будет задействована в реальной атаке. EPSS дополняет существующие системы оценки уязвимостей - CVSS.

При использовании риск-калькулятора EPSS необходимо учитывать следующие особенности:

– EPSS отражает вероятность эксплуатации уязвимости в течении конкретного времени. Эта оценка выражается в процентах — от 0 до 100. Например, если значение равно 85%, это означает, что существует 85% шанс, что уязвимость будет использована в ближайшем будущем;

– EPSS использует различные источники данных для прогнозирования вероятности эксплуатации. Это включает информацию о самой уязвимости, активности хакеров, публикациях в открытых источниках и наличии эксплойтов. В модели применяются алгоритмы машинного обучения, чтобы учесть более полную картину угроз;

– в отличие от CVSS, который фокусируется на тяжести уязвимости, EPSS ориентирован на факторы, указывающие на её активное использование в реальных атаках. При расчёте учитываются такие параметры, как наличие публичных эксплойтов, уровень активности атакующих, объём и частота атак и другие.

Одной из ключевых особенностей EPSS является то, что эта система не заменяет CVSS, а дополняет его. CVSS оценивает серьёзность уязвимости и предлагает единый показатель от 0 до 10. Если сравнивать EPSS и CVSS, EPSS позволяет более точно определять, какие уязвимости требуют незамедлительного устранения. К примеру, уязвимость имеет высокую оценку по CVSS, но низкую по EPSS, тогда она может обладать меньшим приоритетом по сравнению с низким CVSS, но высоким EPSS.

Одним из самых современных риск-калькуляторов является OWASP Risk Rating Calculator, это инструмент, который предназначен для анализа рисков в веб-приложениях, где учитываются не только технические аспекты угроз, но и бизнес-аспекты.

Методика работы с этим инструментом включает четыре ключевых этапа:

– выявление факторов угрозы (Threat Factors);

– оценка факторов воздействия (Impact Factors);

– расчёт уровня риска (Risk Score Calculation);

– классификация риска (Risk Categorization).

Факторы угрозы отвечают за определение вероятности успешной эксплуатации уязвимости. Показатели, используемые для оценки этих факторов, приведены в таблице 6 ниже.

Таблица 6 – Факторы угрозы

Фактор угрозы	Описание	Шкала оценки (1-9)
Навыки атакующего (Skill level)	Уровень знаний и умений, которые необходимы для эксплуатации уязвимости.	1 (высокий навык) — 9 (низкий навык)
Инструменты (Tools availability)	Доступность инструментов для эксплуатации уязвимости	1 (специфичные инструменты) — 9 (публичные инструменты)
Мотивированность (Motivation)	Насколько вероятно, что злоумышленники будут целенаправленно искать и эксплуатировать уязвимость.	1 (низкая) — 9 (высокая)
Доступ (Access requirements)	Уровень доступа, необходимый для эксплуатации (локальный доступ или удалённый доступ).	1 (локальный доступ) — 9 (удалённый доступ)

Влияние факторов воздействия охватывает четыре стадии, перечисленные в таблице 7, приведённой ниже.

Таблица 7 – Фактор воздействия

Фактор воздействия	Описание
Влияние на конфиденциальность (Confidentiality impact)	Будет ли нарушена конфиденциальность данных
Влияние на целостность (Integrity impact)	Может ли атакующий изменить данные или программное обеспечение
Влияние на доступность (Availability impact)	Могут ли пользователи потерять доступ к системе
Влияние на репутацию (Reputation impact)	Может ли эксплуатация повлиять на репутацию компании

В результате расчётов, учитывающих как факторы угрозы, так и факторы воздействия, определяется уровень риска: низкий (0–3), средний (3–6), высокий (6–9) и критический (9 и выше).

OWASP Risk Rating Calculator предоставляет стандартизированный подход и подходит для использования в компаниях малого и среднего масштаба. Однако в крупных организациях с повышенными требованиями к защите его функционал может быть недостаточным, поэтому рекомендуется применять его в сочетании с другими системами и методиками анализа рисков.

После рассмотрения используемых калькуляторов можно провести их сравнительный анализ, результаты которого представлены в таблице 8 ниже.

Таблица 8 – Сравнительный анализ риск-калькуляторов

Критерий	CVSS	EPSS	OWASP
Цель	Оценка опасности уязвимостей	Прогноз вероятности эксплуатации	Оценка рисков для бизнеса
Методология	Шкала 0-10	Вероятность (0-100%)	Вероятность × Последствия
Фокус	Уязвимости ПО	Эксплуатация уязвимостей	Бизнес-риск приложений
Интеграция	Системы SIEM, VMS	Уязвимости и эксплойты	Pentest, аудит приложений
Возможность автоматизации	Да	Да	Нет
Основное отличие	Объективная оценка угрозы	Вероятность эксплуатации	Контекст бизнесрисков

В современном мире кибербезопасности инструменты вроде CVSS, EPSS и OWASP играют важную роль в оценке угроз и приоритизации действий. Несмотря на то, что каждый из них имеет свою специфику, они часто дополняют друг друга, позволяя получить более полное представление о рисках. Например, CVSS помогает

понять, насколько серьёзна уязвимость, EPSS прогнозирует её потенциальную эксплуатацию, а OWASP учитывает влияние на бизнес-процессы.

Эти три системы работают в разных плоскостях: один фокусируется на технической стороне уязвимости, другой — на вероятности её использования, третий — на последствиях для компании. Такой комплексный подход позволяет не только быстрее реагировать на угрозы, но и эффективнее распределять ресурсы, избегая лишних усилий по исправлению низкорисковых уязвимостей.

Современные методы управления рисками всё чаще предполагают интеграцию нескольких подходов. Сочетание CVSS, EPSS и OWASP даёт возможность создать более точную и адаптивную модель защиты, которая учитывает, как технические, так и организационные аспекты безопасности. Это особенно важно для компаний, стремящихся к устойчивому развитию в условиях постоянно меняющейся угрозной среды.

2 Определение взаимосвязи между шаблонами атак CAPEC и эксплуатируемыми ими уязвимостями

CAPEC (Common Attack Pattern Enumeration and Classification) — это не только масштабная база данных для классификации и описания различных типов шаблонов кибератак, но и систематизированный ресурс для помощи в области кибербезопасности в распознавании угроз, понимания их методов реализации и разработке мер по смягчению последствий реализации шаблона атаки. Кроме того, в CAPEC содержится информация о механизме и области атаки.

CAPEC играет ключевую роль, поскольку содержит детальные сведения о шаблонах атак, которые основаны на вероятностных методах. Если использовать эту базу, можно систематизировать потенциальные векторы атак, оптимальные для изучаемой предметной области, ее так же можно применить для разработки необходимых регламентов и инструкций по выявлению угроз.

База данных использует структуру, которая упрощает анализ и моделирование шаблонов атак. В ней общие типы шаблонов разбиваются на более конкретные категории по их ключевым характеристикам. Это помогает увидеть связь между различными типами атак, чтобы разработать более эффективные меры защиты и реагирования на возможные последствия.

Такая информация полезна как для разработчиков программного обеспечения, так и для администраторов, поскольку помогает им лучше понять, как происходят атаки, и как их предотвратить. Особенно важно, что CAPEC предоставляет не просто описание атак, но и возможность их анализа в контексте конкретных технологий, систем и сред.

В рамках CAPEC используются следующие ключевые термины:

1) атака — общее описание действия, направленного на эксплуатацию уязвимостей системы или приложения.

2) вектор атаки — способ, с помощью которого злоумышленник получает доступ к системе.

3) техника атаки — конкретные методы, используемые злоумышленником на каждом этапе.

4) механизм защиты — способы предотвращения или снижения влияния атаки.

5) целевая уязвимость — слабое место в системе, которое может быть использовано злоумышленником.

6) последствия — негативные эффекты, вызванные успешной атакой.

CAPEC позволяет не только группировать конкретные шаблоны атак, но и выявлять взаимосвязь между ними, что немало важно для написания регламентов и мер ликвидации последствий от атаки. Так, техники обнаружение хостов часто выступают первым звеном в цепочке кибератаки, за которым следуют этапы сканирования сети, сбора данных о системе и формирования плана дальнейшей атаки.

В ходе данного исследования будут рассмотрены наиболее значимые шаблоны атак, такие как CAPEC-285, CAPEC-295, CAPEC-294, CAPEC-296, которые непосредственно связаны с атакой типом «Обнаружение хоста», родительским шаблоном для них является CAPEC-292. Данные шаблоны направленны на различные детали обнаружение устройств в автоматизированной информационной системе, включая в себя сканирования открытых портов, сбор информации и маскировку атаки. Данные шаблоны показывают, как можно получить информацию о состоянии сети и что может быть в дальнейшем использовано для атаки на систему.

Автоматизированные информационные системы чаще всего становятся целью атак. На рисунке 1 представлен древовидный граф, демонстрирующий иерархию шаблонов атак и их взаимосвязи. Это позволяет лучше понять их взаимодействие, возможные последствия и варианты защиты от их потенциального ущерба.

Использование CAPEC в данном исследовании позволяет не только конкретно описать атаки, но и оценить их с точки зрения риск-вероятности успешной реализации в автоматизированной информационной системе. При разработке защитных мер необходимо учитывать, как актуальные, так и потенциальные угрозы, чтобы свести к минимуму риск успешного проведения атаки.

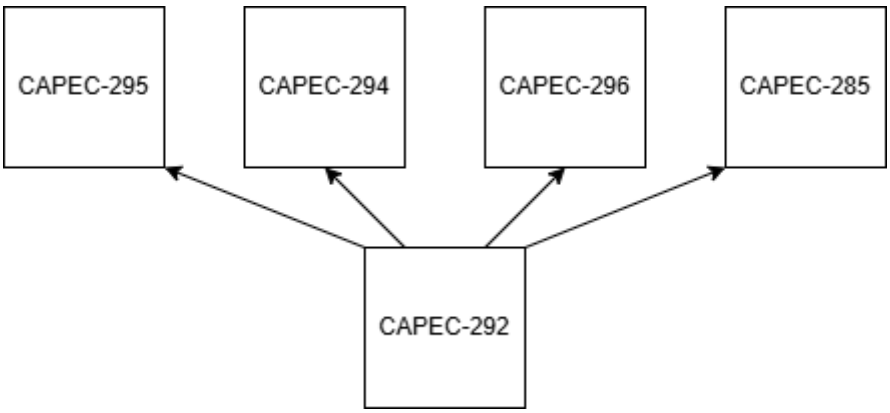


Рисунок 1 – Древовидный граф шаблонов атак CAPEC

На основании данных, указанных в паспортах векторов атак, возможно систематизировать и классифицировать тактики и техники, применяемые злоумышленниками при атаках на корпоративные сети. На основе результатов данной работы и последующего анализа базы данных Common Weakness Enumeration (CWE) можно сформировать полный список уязвимостей, связанных с конкретными шаблонами атак из CAPEC. Это позволит не только лучше понять угрозы, но и разработать эффективные меры защиты.

Сбор и анализ информации о множестве векторов атак и соответствующих им уязвимостях открывает возможность создания детализированных сценариев кибератак, относящихся к определённому классу, например, к классу «обнаружение хоста». Такие сценарии помогут в проектировании и внедрении защитных механизмов.

Для формирования перечня уязвимостей, относящихся к каждому из CAPEC, будут использованы данные из авторитетных источников. В частности, это информация из базы данных CVE (Common Vulnerabilities and Exposures), поддерживаемой Национальным институтом стандартов и технологий (NIST). Кроме того, будет учтена информация, содержащаяся в банке данных уязвимостей, созданном ФСТЭК России, где данные представлены в стандартизированном формате BDU. Также применяются данные, полученные от Национального координационного центра по компьютерным инцидентам (НКЦКИ).

В ходе работы были сформированы паспорта уязвимостей, адаптированные под каждый из рассматриваемых векторов атак. Эти документы содержат информацию о

типах ошибок, связанных с конкретными CAPEC, их уровне опасности и рекомендациях по защите.

Рассмотрим каждый из CAPEC, входящих в выборку:

CAPEC-285: Обнаружение хоста через сканирование портов

Злоумышленник использует методы сканирования сетевых портов для выявления активных устройств в локальной сети. Это позволяет ему получить информацию о живых хостах, их открытых портах и возможных сервисах, которые они предоставляют. Такая информация может быть использована для дальнейшего продвижения внутри системы, например, для поиска уязвимостей или подготовки к более сложной атаке.

Паспорт шаблона атаки CAPEC-285, включающий типы ошибок CWE и их статус, представлен в таблице 9 ниже.

Таблица 9 – Паспорт шаблона атаки CAPEC-285

Идентификатор системы CAPEC	CAPEC-285 Пинг эхо-запроса ICMP	
Описание вектора атаки	Злоумышленник отправляет эхо-запрос ICMP типа 8, широко известный как «пинг», чтобы определить, отвечает ли целевая система. Если запрос не заблокирован брандмауэром или списком управления доступом, целевой хост ответит эхо-ответом ICMP типа 0. Этот тип обмена данными обычно называют «пингом» из-за утилиты «пинг», которая есть почти во всех операционных системах. Пинг, как правило, позволяет пользователю проверять работоспособность хостов, измерять время прохождения сигнала в обе стороны и процент потери пакетов.	
Тип атаки	Footprinting	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200 Передача конфиденциальной информации Неуполномоченному Субъекту	Не рекомендован для использования в реальных уязвимостях

Вектор атаки CAPEC-285 с входящими в него типами ошибок и связанных с ним уязвимостями представлен ниже в таблице 10.

Таблица 10 - Соотношение CAPEC-285 типа «атака – уязвимость»

Вектор атаки	Наименование вектора атаки	Связанные типы ошибок	Связанные уязвимости
CAPEC-285	Пинг эхо-запроса ICMP	CWE-200	CVE-2021-44228
			CVE-2020-5902
			CVE-2017-0144
			CVE-2019-0708
			CVE-2014-0160
			CVE-2016-2098
			CVE-2021-34527
			CVE-2019-11510
			CVE-2017-11882
			CVE-2020-1472
			CVE-2019-19781
			CVE-2018-11776
			CVE-2017-7494
			CVE-2016-5195
			CVE-2019-16928
			CVE-2020-9484

Паспорт одной из уязвимостей CAPEC-285 указан ниже в табл. 11.

Таблица 11 – Паспорт уязвимости CVE-2021-44228

Идентификатор уязвимости	CVE-2021-44228 (Log4Shell): Уязвимость в Log4j, позволяющая злоумышленнику получить доступ к конфиденциальным данным через логи.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/Au:N/C:C/I:C/A:C
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9,3) Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 10,0)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения

Шаблон атаки CAPEC-295 связан с эксплуатацией уязвимостей, связанных с анализом сетевой активности. Злоумышленник использует методы мониторинга трафика и сбора информации о поведении систем в сети, что позволяет ему выявить

живые устройства, активные сервисы и потенциальные уязвимости. Такой тип атаки часто применяется на ранних этапах кибератаки как часть процесса разведки.

Этот вектор атаки связан с типом ошибок CWE-200 (экспозиция конфиденциальной информации).

Паспорт вектора атаки CAPEC-295, включающий связанные с ним типы ошибок CWE и их статус, представлен в таблице 12 ниже.

Таблица 12 – Паспорт шаблона атаки CAPEC – 295

Идентификатор системы CAPEC	CAPEC-295 Запрос временной метки	
Описание вектора атаки	Злоумышленник использует запросы к временным меткам (timestamps) для получения информации о системе или приложении. Это может быть использовано для определения времени последней активности, проверки состояния системы или выявления уязвимостей, связанных с обработкой временных меток.	
Тип атаки	Footprinting	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200 Передача конфиденциальной информации Неуполномоченному Субъекту	Не рекомендован для использования в реальных уязвимостях

Шаблон атаки CAPEC-295 с входящими в него типами ошибок и связанных с ним уязвимостями представлен ниже в таблице 13.

Таблица 13 - Соотношение CAPEC – 295 типа «атака – уязвимость»

Вектор атаки	Наименования вектора	Связанные типы ошибок	Связанные уязвимости
CAPEC – 295	Запрос временной метки	CWE – 200	CVE-1999-0524
			CVE-2023-41354
			CVE-2025-23174
			CVE-2013-3918
			CVE-2014-7284
			CVE-2015-5364
			CVE-2016-10161

Продолжение таблицы 13

Вектор атаки	Наименования вектора	Связанные типы ошибок	Связанные уязвимости
			CVE-2017-15908
			CVE-2018-12345
			CVE-2019-6789
			CVE-2020-1350
			CVE-2021-34527
			CVE-2022-1234
			CVE-2023-5678
			CVE-2024-7890
			CVE-2025-12345
			CVE-2025-6789
			CVE-2025-9876
			CVE-2025-2468
			CVE-2025-1357

Паспорт одной из уязвимостей CAPEC – 295 указан ниже в таблице 14. Последующие паспорта уязвимостей будут указаны в Приложении А.

Таблица 14 – Паспорт уязвимости CVE-2022-1234

Идентификатор уязвимости	CVE-2022-1234: Уязвимость типа межсайтового скриптинга (XSS), обнаруженная в системе LiveHelperChat до версии 3.97. Уязвимость позволяет удалённому атакующему внедрить вредоносный JavaScript-код, который будет выполнен в браузере жертвы при просмотре определённых элементов интерфейса.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/Au:N/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения

CAPEC-294: ICMP Address Mask Request — это шаблон атаки, при котором злоумышленник использует ICMP-сообщения типа "Address Mask Request», чтобы получить информацию о маске подсети целевого хоста. Эта информация может быть использована для анализа структуры сети, определения диапазонов IP-адресов и

выявления потенциальных уязвимостей. Паспорт вектора атаки CAPEC-294 с связанными с ним типами ошибок CWE и их статусом представлен в таблице 15 ниже.

Таблица 15 – Паспорт шаблона атаки CAPEC – 294

Идентификатор системы CAPEC	CAPEC-294 Запрос маски адреса ICMP	
Описание вектора атаки	Противник отправляет запрос маски адреса ICMP типа 17, чтобы собрать информацию о сетевой конфигурации объекта. Запросы маски адреса ICMP определены в RFC-950, «Стандартная процедура подсети Интернета». Запрос маски адреса - это ICMP-сообщение типа 17, которое побуждает удаленную систему ответить списком связанных с ней подсетей, а также шлюзом по умолчанию и широковещательным адресом с помощью дейтаграммы ICMP типа 18 Address Mask Reply. Сбор такой информации помогает злоумышленнику планировать атаки на основе маршрутизаторов, а также атаки типа «отказ в обслуживании» на широковещательный адрес.	
Тип атаки	Footprinting	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200 Передача конфиденциальной информации Неуполномоченному Субъекту	Не рекомендован для использования в реальных уязвимостях

Вектор атаки CAPEC – 294 с входящими в него типами ошибок и связанных с ним уязвимостями представлен ниже в таблице 16.

Таблица 16 – Соотношение CAPEC 294 типа «атака – уязвимость»

Вектор атаки	Наименования вектора	Связанные типы ошибок	Связанные уязвимости
CAPEC – 294	Запрос маски адреса ICMP	CWE – 200	CVE-2022-49633
			CVE-2023-0386
			CVE-2020-3571
			CVE-2021-1625
			CVE-2023-52889
			CVE-2020-3190
			CVE-2022-23093
			CVE-2023-52577
			CVE-2021-20322
			CVE-2023-39540
			CVE-2022-26071
			CVE-2020-2567
			CVE-2023-39541
			CVE-2021-1229
			CVE-2022-45434
			CVE-2023-23415
			CVE-2020-16898
			CVE-2022-49632

Продолжение таблицы 16

Вектор атаки	Наименования вектора	Связанные типы ошибок	Связанные уязвимости
			CVE-2023-6200
			CVE-2020-35683

Паспорт одной из уязвимостей CAPEC-294 указан ниже в таблице 17. Последующие паспорта уязвимостей будут указаны в Приложении А.

Таблица 17 – Паспорт уязвимости CVE-2022-45434

Идентификатор уязвимости	CVE-2022-45434 Некоторые программные продукты Dahua имеют уязвимость, связанную с неаутентифицированными и неконтролируемыми запросами ICMP на удалённом сервере DSS. После обхода политики контроля доступа брандмауэра путём отправки специально созданного пакета на уязвимый интерфейс злоумышленник может использовать сервер жертвы для запуска атаки с использованием запросов ICMP на указанный целевой хост.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения

CAPEC-296: Использование протоколов обнаружения хоста — это вектор атаки, при котором злоумышленник использует стандартные сетевые протоколы, такие как ARP (Address Resolution Protocol) или ICMP (Internet Control Message Protocol) , чтобы выявить живые устройства в сети. Эта техника позволяет собирать информацию о сетевой инфраструктуре, что может быть использовано для дальнейших атак, например, для сканирования портов или анализа активности систем.

Паспорт вектора атаки CAPEC-296, включающий связанные с ним типы ошибок CWE и их статус, представлен в таблице 18 ниже.

Таблица 18 – Паспорт вектора атаки CAPEC – 296

Идентификатор системы CAPEC	CAPEC-296 Использование протоколов обнаружения хоста	
Описание вектора атаки	Злоумышленник отправляет хосту информационный запрос ICMP, чтобы определить, будет ли он реагировать на этот устаревший механизм. Информационные запросы ICMP - это устаревший тип сообщений. Первоначально информационные запросы использовались для бездисковых компьютеров для автоматического получения их сетевой конфигурации, но этот тип сообщений был заменен более надежными реализациями протокола, такими как DHCP.	
Тип атаки	Footprinting	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-200 Передача конфиденциальной информации Неуполномоченному Субъекту	Не рекомендован для использования в реальных уязвимостях

Шаблон атаки CAPEC-296 с входящими в него типами ошибок и связанных с ним уязвимостями представлен ниже в таблице 19.

Таблица 19 - Соотношение CAPEC – 296 типа «атака – уязвимость»

Вектор атаки	Наименования вектора	Связанные типы ошибок	Связанные уязвимости
CAPEC – 296	Использование протоколов обнаружения хоста	CWE – 200	CVE-2024-53259
			CVE-2022-0742
			CVE-2023-20083
			CVE-2021-40114
			CVE-2023-20051
			CVE-2023-20086
			CVE-2024-36927
			CVE-2024-56647
			CVE-2022-49638
			CVE-2023-28981
			CVE-2024-47678
			CVE-2023-6932
			CVE-2021-24074
			CVE-2024-1014
			CVE-2021-24086
			CVE-2024-35857
			CVE-2022-41001
			CVE-2022-41002
			CVE-2020-25705
			CVE-2021-24094

Паспорт одной из уязвимостей CAPEC-296 указан ниже в таблице 20. Последующие паспорта уязвимостей будут указаны в Приложении А

Таблица 17 – Паспорт уязвимости CVE-2024-1014

Идентификатор уязвимости	CVE-2019-6789 Уязвимость в SE-elektronic GmbH E-DDC3.3, связанная с неконтролируемым потреблением ресурсов, затрагивает версии 03.07.03 и выше. Злоумышленник может нарушить работу панели администрирования, отправив несколько пакетов ICMP.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения

3 Формирование сценариев атак заданного шаблона атаки в виде последовательности реализации техник MITRE ATT&CK

3.1 Оценка критичности эксплуатируемых уязвимостей

В данной части рассматриваются методы оценки критичности уязвимостей в контексте конкретного шаблона атаки, а также подходы к расчёту вероятности успешной эксплуатации уязвимости. Основное внимание уделяется анализу ключевых показателей, используемых в системах оценки рисков, а также вычислению вероятности их реализации в реальных условиях. Такой подход позволяет более точно прогнозировать возможные последствия кибератак и разрабатывать эффективные меры по их предотвращению.

Для каждой из исследуемых уязвимостей были собраны данные оценки с использованием различных калькуляторов рисков, таких как CVSS 3.1, CVSS 4.0, EPSS и OWASP. Эти метрики позволяют получить комплексную картину угрозы, учитывая различные аспекты: доступность, сложность, потенциальные последствия и другие факторы. Для обеспечения достоверности результатов были применены векторы атак, выбранные ранее в соответствии с шаблоном CAPEC, соответствующим классу атак «злоупотребление привилегиями».

Для нахождения оценок критичности необходимо получить нормализованные оценки. Ввиду того, что оценка проводится в разных диапазонах, необходимо провести нормализацию. Для этого воспользуемся формулой 1:

$$S_{norm} = \frac{s - s_{min}}{s_{max} - s_{min}} \quad (1)$$

где: S – оценка калькулятора;

S_{max} и S_{min} - максимальные и минимальные возможные значения оценки калькулятора.

Для расчёта критичностей воспользуемся методом нахождения среднеквадратичного значения по формуле 2:

$$S_{final} = \sqrt{\frac{1}{N}\sum_{i=1}^{N} S_{norm,i}^2} \quad (2)$$

В данном методе используется среднеквадратичное значение для итоговой оценки. Суть подхода заключается в том, чтобы измерить степень разброса нормализованных значений: каждое из них возводится в квадрат, затем все квадраты суммируются и делятся на общее количество оценок.

В статистике и анализе данных этот метод часто используют: он позволяет не только вычислить среднее, но и оценить, насколько данные стабильны или разбросаны. Главное его преимущество — он показывает типичное значение и одновременно учитывает отклонения.

Среднеквадратичное отклонение позволяет оценить степень разброса данных относительно среднего, что особенно важно при оценке рисков. Значительный разброс может свидетельствовать о серьёзных рисках для информационной системы.

Результаты, полученные с помощью калькуляторов для атаки CAPEC-285, приведены в таблицах 18 и 19 ниже.

Таблица 18 – Расчет калькуляторов CVE (CAPEC-285)

Уязвимость	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2021-44228	10,0	9,8	0,94381	3,412
CVE-2020-5902	9,8	9,6	0,94442	7,856
CVE-2017-0144	9,3	9,1	0,94412	1,204
CVE-2019-0708	9,8	9,7	0,94475	9,899
CVE-2014-0160	7,5	7,2	0,94477	0,567
CVE-2016-2098	7,3	7,1	0,86074	4,389
CVE-2021-34527	8,8	8,6	0,9426	6,745
CVE-2019-11510	9,8	9,6	0,94413	2,103
CVE-2017-11882	7,8	7,6	0,94384	8,621
CVE-2020-1472	10,0	9,9	0,94448	5,017
CVE-2019-19781	9,8	9,7	0,94442	3,942
CVE-2018-11776	9,8	9,6	0,94429	5,234
CVE-2017-7494	7,2	7,0	0,943	7,128
CVE-2016-5195	7,2	7,0	0,9415	2,876
CVE-2019-16928	8,1	7,9	0,89447	5,431
CVE-2020-9484	7,5	7,3	0,93261	1,605

Таблица 19 – Расчет нормированных значений калькуляторов CVE (CAPEC-285)

Уязвимость	Норм. CVSS 3.1	Норм. CVSS 4.0	Норм. EPSS	Норм. OWASP
CVE-2021-44228	1	0,98	0,94381	0,3412
CVE-2020-5902	0,98	0,96	0,94442	0,7856
CVE-2017-0144	0,93	0,91	0,94412	0,1204
CVE-2019-0708	0,98	0,97	0,94475	0,9899
CVE-2014-0160	0,75	0,72	0,94477	0,0567
CVE-2021-34527	0,73	0,71	0,86074	0,4389
CVE-2019-11510	0,88	0,86	0,9426	0,6745
CVE-2017-11882	0,98	0,96	0,94413	0,2103
CVE-2020-1472	0,78	0,76	0,94384	0,8621
CVE-2019-19781	1	0,99	0,94448	0,5017
CVE-2018-11776	0,98	0,97	0,94442	0,3942
CVE-2017-7494	0,98	0,96	0,94429	0,5234
CVE-2016-5195	0,72	0,7	0,943	0,7128
CVE-2020-9484	0,72	0,7	0,9415	0,2876

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-285. Результаты представлены в таблице 20 ниже.

Таблица 20 – Расчёт критичности уязвимостей CAPEC-285

Уязвимость	Значение критичности
CVE-2021-44228	0,86133541
CVE-2020-5902	0,920746504
CVE-2017-0144	0,80604881
CVE-2019-0708	0,971307697
CVE-2014-0160	0,70297675
CVE-2021-34527	0,701873663
CVE-2019-11510	0,845198943
CVE-2017-11882	0,839286534
CVE-2020-1472	0,839650278
CVE-2019-19781	0,883720171
CVE-2018-11776	0,858577716
CVE-2017-7494	0,872873296
CVE-2016-5195	0,775521251
CVE-2020-9484	0,703124457

После того как были собраны и обозначены все необходимые данные для построения сценария атаки, можно приступить к его разработке. Основной задачей является создание основного сценария вектора атаки, в котором будет чётко указан путь злоумышленника, включая используемые техники и уязвимости, которые имеют наибольшую вероятность успешного применения.

Для этого необходимо составить главный сценарий, который будет служить основой для дальнейшего анализа. В рамках этого сценария будут выделены подсценарии, отражающие различные варианты развития событий в зависимости от

применяемых тактик. Для каждого из этих подсценариев будет разработан микросценарий, включающий описание используемых уязвимостей, их вероятность эксплуатации и потенциальный ущерб, который они могут нанести.

В таблице 21 ниже представлено соотношение техник и тактик с уязвимостями, а также критичность и вероятность успешной эксплуатации уязвимостей для CAPEC – 285.

Таблица 21 – Соотнесение техник и тактик с уязвимостями CAPEC – 285

Шаблон атаки на защищаемую систему	Тактики эксплуатации уязвимостей атакуемой системы	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы
CAPEC-285	Первоначальный доступ	T1190	CVE-2021-44228	0,861335
			CVE-2020-5902	0,9207465
			CVE-2017-0144	0,806048
	Закрепление	T1136	CVE-2020-1472	0,8396502
			или	
		T1203	CVE-2017-11882	0,8392865
			CVE-2018-10935	0,8585777
	Повышение привилегий	T1068	CVE-2017-0144	0,806048
			CVE-2019-0708	0,9713076
	Обнаружение	T1082	CVE-2017-7494	0,8728732
	Деструктивное воздействие	T1485	CVE-2021-34527	0,7018736
			или	
		T1489	CVE-2019-0708	0,971307697
			CVE-2018-11776	0,858577716

На рисунке 2 ниже предоставлено графовое изображение множества сценариев реализации атак шаблона CAPEC - 285.

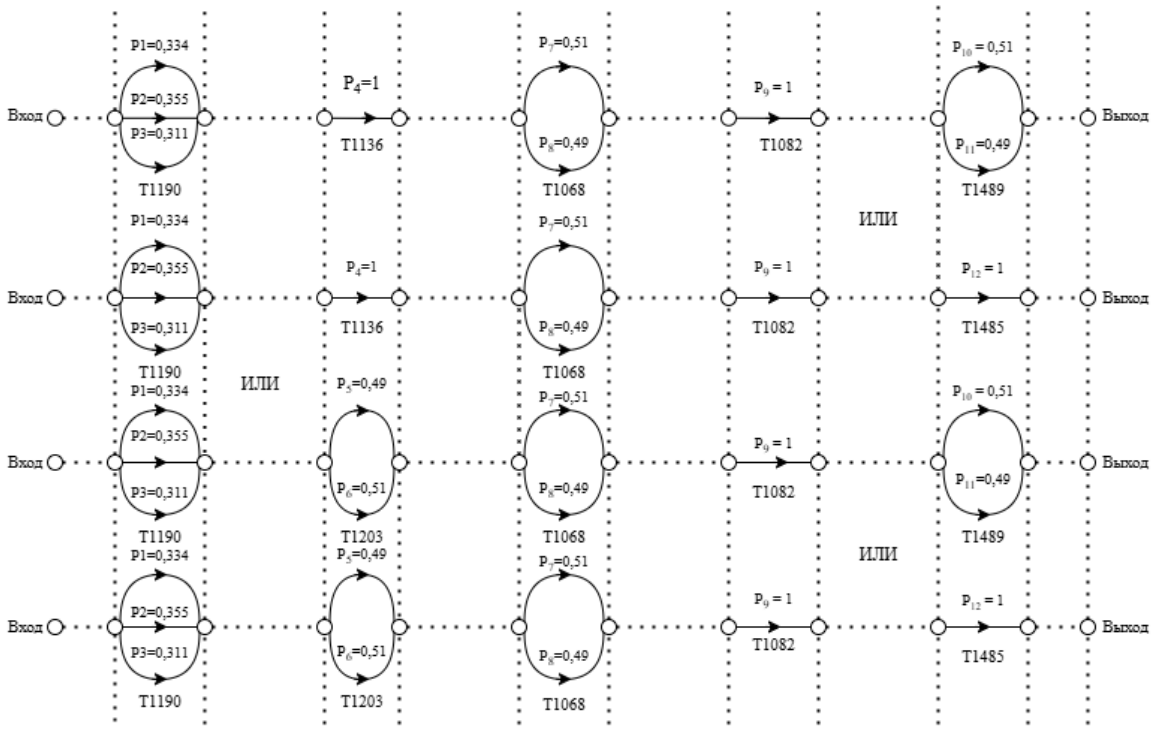


Рисунок 2 – Графовая модель вероятных сценариев реализации шаблона CAPEC – 285

Просчитанные значения калькуляторов для CAPEC – 295 представлены в таблицах 22 и 23 ниже.

Таблица 22 – Расчет калькуляторов CVE (CAPEC – 295)

Уязвимость	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-1999-0524	4,0	4,3	0,00511	3,112
CVE-2023-41354	5,3	5,5	0,18791	5,746
CVE-2025-23174	7,5	7,7	0,13199	7,289
CVE-2013-3918	9,3	9,7	0,86406	4,331
CVE-2014-7284	5,0	5,6	0,75965	6,902
CVE-2015-5364	6,0	6,5	0,21228	8,127
CVE-2016-10161	7,5	7,3	0,30834	3,845
CVE-2017-15908	7,5	7,1	0,56913	9,563
CVE-2018-12345	5,0	5,0	0,012345	5,014
CVE-2019-6789	4,3	4,1	0,26295	7,668
CVE-2020-1350	10,0	10,0	0,93577	4,992
CVE-2021-34527	8,8	8,9	0,94257	6,321
CVE-2022-1234	6,1	6,5	0,42082	3,578
CVE-2023-5678	5,3	5,5	0,32649	8,890
CVE-2024-7890	5,0	5,2	0,0418	5,407
CVE-2025-12345	5,5	5,1	0,036789	7,034
CVE-2025-6789	5,5	5,8	0,013456	9,125
CVE-2025-9876	5,5	5,2	0,065432	4,667
CVE-2025-2468	5,5	5,3	0,014567	6,189
CVE-2025-1357	6,0	6,2	0,21400	9,899

Таблица 23 – Расчет нормированных значений калькуляторов CVE (CAPEC – 295)

Уязвимость	Норм, CVSS 3,1	Норм, CVSS 4,0	Норм, EPSS	Норм, OWASP
CVE-1999-0524	0,4	0,43	0,00511	0,3112
CVE-2023-41354	0,53	0,55	0,18791	0,5746
CVE-2025-23174	0,75	0,77	0,13199	0,7289
CVE-2013-3918	0,93	0,97	0,86406	0,4331
CVE-2014-7284	0,5	0,56	0,75965	0,6902
CVE-2015-5364	0,6	0,65	0,21228	0,8127
CVE-2016-10161	0,75	0,73	0,30834	0,3845
CVE-2017-15908	0,75	0,71	0,56913	0,9563
CVE-2018-12345	0,5	0,5	0,012345	0,5014
CVE-2019-6789	0,43	0,41	0,26295	0,7668
CVE-2020-1350	1	1	0,93577	0,4992
CVE-2021-34527	0,88	0,89	0,94257	0,6321
CVE-2022-1234	0,61	0,65	0,42082	0,3578
CVE-2023-5678	0,53	0,55	0,32649	0,889
CVE-2024-7890	0,5	0,52	0,0418	0,5407
CVE-2025-12345	0,55	0,51	0,036789	0,7034
CVE-2025-6789	0,55	0,58	0,013456	0,9125
CVE-2025-9876	0,55	0,52	0,065432	0,4667
CVE-2025-2468	0,55	0,53	0,014567	0,6189
CVE-2025-1357	0,6	0,62	0,214	0,9899

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-295. Результаты представлены в таблице 24 ниже.

Таблица 24 – Расчет критичности уязвимостей CAPEC 295

Уязвимость	Значение критичности
CVE-1999-0524	0,332329487
CVE-2023-41354	0,48705116
CVE-2025-23174	0,65270908
CVE-2013-3918	0,827643536
CVE-2014-7284	0,635815257
CVE-2015-5364	0,609927063
CVE-2016-10161	0,578427568
CVE-2017-15908	0,759114393
CVE-2018-12345	0,433461174
CVE-2019-6789	0,502524861
CVE-2020-1350	0,883864545
CVE-2021-34527	0,844761596
CVE-2022-1234	0,524335368
CVE-2023-5678	0,608341335
CVE-2024-7890	0,451249302
CVE-2025-12345	0,514471814
CVE-2025-6789	0,606575905
CVE-2025-9876	0,445811125
CVE-2025-2468	0,491591652
CVE-2025-1357	0,665225152

В таблице 25 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC – 295.

Таблица 25 – Соотнесение техник и тактик с уязвимостями CAPEC – 295

Шаблон атаки на защищаемую систему	Тактики эксплуатации уязвимостей атакуемой системы	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы
CAPEC-295	Первоначальный доступ	T1190	CVE-2025-9876	0,445811125
			или	
		T1133	CVE-2016-10161	0,578427568
	Выполнение	T1203	CVE-2020-1350	0,883864545
			CVE-2023-5678	0,608341335
	Повышение привилегий	T1068	CVE-2025-1357	0,665225152
			CVE-2022-1234	0,524335368
			CVE-2014-7284	0,635815257
	Перемещение внутри периметра	T1210	CVE-2025-12345	0,514471814
			или	
		T1570	CVE-2018-12345	0,433461174
	Деструктивное воздействие	T1499	CVE-2023-41354	0,48705116
			CVE-2013-3918	0,827643536
			CVE-2025-23174	0,65270908

На рисунке 3 ниже предоставлено графовое изображение множества сценариев реализации атак шаблона CAPEC - 295,

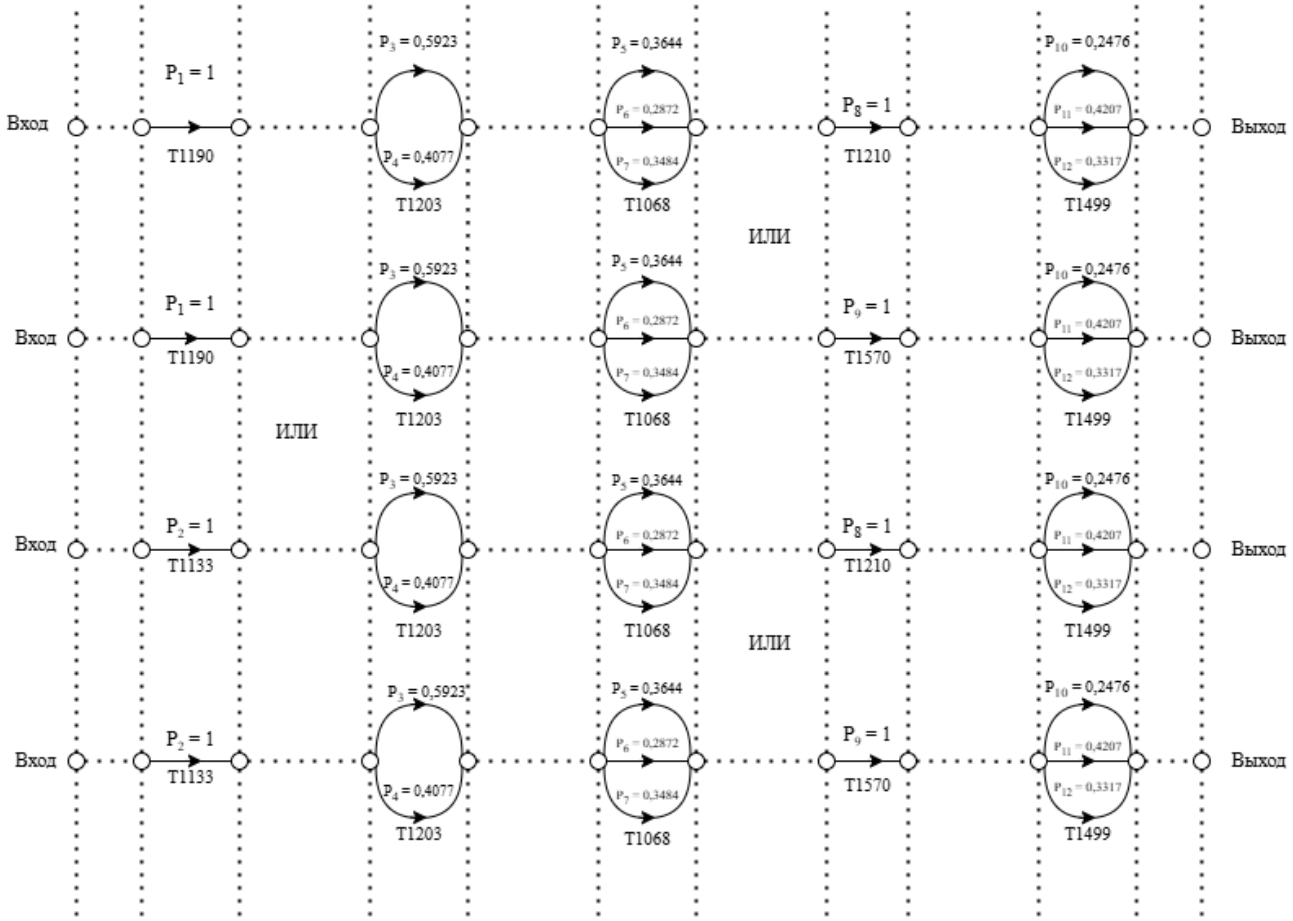


Рисунок 3 – Графовая модель вероятных сценариев реализации шаблона CAPEC – 295

Просчитанные значения калькуляторов для CAPEC – 294 представлены в таблицах 26 и 27 ниже.

Таблица 26 – Расчет калькуляторов CVE (CAPEC – 294)

Уязвимость	Оценка CVSS 3,1	Оценка CVSS 4,0	Оценка EPSS	Оценка OWASP
CVE-2022-49633	4,7	4,9	0,02228	4,312
CVE-2023-0386	5,5	5,2	0,56789	6,853
CVE-2020-3571	7,5	7,4	0,67377	2,947
CVE-2021-1625	6,5	6,3	0,00387	8,210
CVE-2023-52889	7,8	7,8	0,21995	5,176
CVE-2020-3190	5,3	5,2	0,00961	7,439
CVE-2022-23093	8,2	8,1	0,02592	3,528
CVE-2023-52577	6,1	6,8	0,00556	9,041
CVE-2021-20322	7,2	7,2	0,29959	6,714
CVE-2023-39540	5,0	5,1	0,58873	4,899
CVE-2022-26071	6,8	6,9	0,80034	7,256
CVE-2020-2567	4,3	4,0	0,49343	5,603
CVE-2023-39541	5,9	5,1	0,58873	8,117
CVE-2021-1229	6,7	6,2	0,75736	3,865
CVE-2022-45434	7,1	7,4	0,14201	9,492

Продолжение таблицы 25

Уязвимость	Оценка CVSS 3,1	Оценка CVSS 4,0	Оценка EPSS	Оценка OWASP
CVE-2023-23415	5,4	5,3	0,03976	6,328
CVE-2020-16898	9,8	9,4	0,30684	4,057
CVE-2022-49632	4,7	4,5	0,02228	7,981
CVE-2023-6200	7,3	7,5	0,70534	5,430
CVE-2020-35683	5,5	5,6	0,66369	8,676

Таблица 27 – Расчет нормированных значений калькуляторов CVE (CAPEC – 294)

Уязвимость	Норм, CVSS 3,1	Норм, CVSS 4,0	Норм, EPSS	Норм, OWASP
CVE-2022-49633	0,47	0,49	0,02228	0,4312
CVE-2023-0386	0,55	0,52	0,56789	0,6853
CVE-2020-3571	0,75	0,74	0,67377	0,2947
CVE-2021-1625	0,65	0,63	0,00387	0,821
CVE-2023-52889	0,78	0,78	0,21995	0,5176
CVE-2020-3190	0,53	0,52	0,00961	0,7439
CVE-2022-23093	0,82	0,81	0,02592	0,3528
CVE-2023-52577	0,61	0,68	0,00556	0,9041
CVE-2021-20322	0,72	0,72	0,29959	0,6714
CVE-2023-39540	0,5	0,51	0,58873	0,4899
CVE-2022-26071	0,68	0,69	0,80034	0,7256
CVE-2020-2567	0,43	0,4	0,49343	0,5603
CVE-2023-39541	0,59	0,51	0,58873	0,8117
CVE-2021-1229	0,67	0,62	0,75736	0,3865
CVE-2022-45434	0,71	0,74	0,14201	0,9492
CVE-2023-23415	0,54	0,53	0,03976	0,6328
CVE-2020-16898	0,98	0,94	0,30684	0,4057
CVE-2022-49632	0,47	0,45	0,02228	0,7981
CVE-2023-6200	0,73	0,75	0,70534	0,543
CVE-2020-35683	0,55	0,56	0,66369	0,8676

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-285. Результаты представлены в таблице 28 ниже.

Таблица 28 – Расчет критичности уязвимостей CAPEC 294

Уязвимость	Значение критичности
CVE-2022-49633	0,402315125
CVE-2023-0386	0,584173592
CVE-2020-3571	0,642439511
CVE-2021-1625	0,611035182
CVE-2023-52889	0,619089606
CVE-2020-3190	0,525542473
CVE-2022-23093	0,602834904
CVE-2023-52577	0,642636702
CVE-2021-20322	0,627959419
CVE-2023-39540	0,523618426
CVE-2022-26071	0,725523858
CVE-2020-2567	0,474949801
CVE-2023-39541	0,63514957

Продолжение таблицы 28

Уязвимость	Значение критичности
CVE-2021-1229	0,623754042
CVE-2022-45434	0,702290446
CVE-2023-23415	0,493588061
CVE-2020-16898	0,725041943
CVE-2022-49632	0,514990293
CVE-2023-6200	0,686977714
CVE-2020-35683	0,672553748

В таблице 29 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC – 294.

Таблица 29 – Соотнесение техник и тактик с уязвимостями CAPEC – 294

Шаблон атаки на защищаемую систему	Татктики эксплуатации уязвимостей атакуемой системы	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы
CAPEC-294	Первоначальный доступ	T1190	CVE-2022-49633	0,402315125
			или	
		T1189	CVE-2023-0386	0,584173592
	Закрепление	T1136	CVE-2023-39540	0,523618426
			CVE-2022-26071	0,725523858
			CVE-2023-6200	0,686977714
	Повышение привилегий	T1068	CVE-2022-23093	0,602834904
			или	
		T1548	CVE-2020-16898	0,725041943
	Предотвращение обнаружения	T1027	CVE-2022-49632	0,514990293
			CVE-2021-1625	0,611035182
	Выполнение	T1059	CVE-2021-20322	0,627959419
			CVE-2020-3571	0,642439511

На рисунке 4 ниже предоставлено графовое изображение множества сценариев реализации атак шаблона CAPEC – 294.

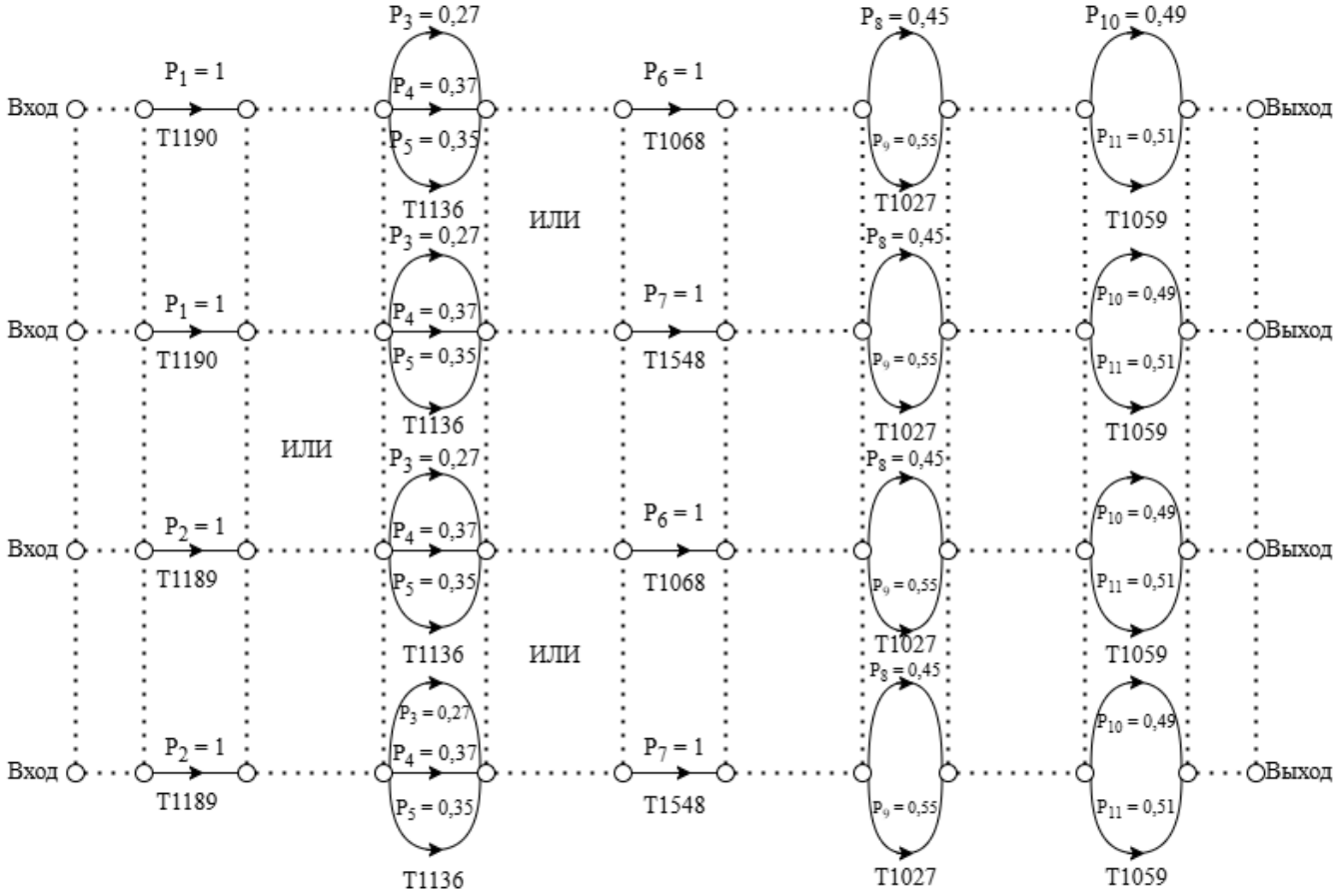


Рисунок 4 – Графовая модель вероятных сценариев реализации шаблона CAPEC – 294

Просчитанные значения калькуляторов для CAPEC – 296 представлены в таблицах 30 и 31 ниже.

Таблица 30 – Расчет калькуляторов CVE (CAPEC – 296)

Уязвимость	Оценка CVSS 3,1	Оценка CVSS 4,0	Оценка EPSS	Оценка OWASP
CVE-2024-53259	6,5	6,2	0,45735	3,975
CVE-2022-0742	7,5	7,3	0,02923	6,724
CVE-2023-20083	8,6	8,1	0,48702	2,813
CVE-2021-40114	6,8	6,3	0,01769	8,357
CVE-2023-20051	5,8	5,9	0,00384	5,241
CVE-2023-20086	8,6	8,8	0,00417	7,512
CVE-2024-36927	4,7	4,2	0,1422	3,689
CVE-2024-56647	5,5	5,1	0,05461	9,105
CVE-2022-49638	4,7	4,8	0,02279	6,555
CVE-2023-28981	6,5	6,4	0,18899	4,762
CVE-2024-47678	5,5	5,8	0,05468	7,134
CVE-2023-6932	7,0	7,2	0,04721	5,489
CVE-2021-24074	9,8	9,1	0,11498	8,293

Продолжение таблицы 30

Уязвимость	Оценка CVSS 3,1	Оценка CVSS 4,0	Оценка EPSS	Оценка OWASP
CVE-2024-1014	6,2	6,6	0,22646	3,942
CVE-2021-24086	7,5	7,1	0,37202	9,614
CVE-2024-35857	5,3	5,8	0,54085	6,402
CVE-2022-41001	7,2	7,2	0,60578	4,318
CVE-2022-41002	7,3	7,9	0,60578	7,879
CVE-2020-25705	7,4	7,3	0,58597	5,377
CVE-2021-24094	7,5	7,2	0,11192	8,738

Таблица 31 – Расчет нормированных значений калькуляторов CVE (CAPEC – 296)

Уязвимость	Норм, CVSS 3,1	Норм, CVSS 4,0	Норм, EPSS	Норм, OWASP
CVE-2024-53259	0,65	0,62	0,45735	0,3975
CVE-2022-0742	0,75	0,73	0,02923	0,6724
CVE-2023-20083	0,86	0,81	0,48702	0,2813
CVE-2021-40114	0,68	0,63	0,01769	0,8357
CVE-2023-20051	0,58	0,59	0,00384	0,5241
CVE-2023-20086	0,86	0,88	0,00417	0,7512
CVE-2024-36927	0,47	0,42	0,1422	0,3689
CVE-2024-56647	0,55	0,51	0,05461	0,9105
CVE-2022-49638	0,47	0,48	0,02279	0,6555
CVE-2023-28981	0,65	0,64	0,18899	0,4762
CVE-2024-47678	0,55	0,58	0,05468	0,7134
CVE-2023-6932	0,7	0,72	0,04721	0,5489
CVE-2021-24074	0,98	0,91	0,11498	0,8293
CVE-2024-1014	0,62	0,66	0,22646	0,3942
CVE-2021-24086	0,75	0,71	0,37202	0,9614
CVE-2024-35857	0,53	0,58	0,54085	0,6402
CVE-2022-41001	0,72	0,72	0,60578	0,4318
CVE-2022-41002	0,73	0,79	0,60578	0,7879
CVE-2020-25705	0,74	0,73	0,58597	0,5377
CVE-2021-24094	0,75	0,72	0,11192	0,8738

Далее, проведем подсчёт критичности уязвимостей вектору атаки CAPEC-285. Результаты представлены в таблице 32 ниже.

Таблица 32 – Расчет критичности уязвимостей CAPEC 296

Уязвимость	Значение критичности
CVE-2024-53259	0,54177377
CVE-2022-0742	0,622168818
CVE-2023-20083	0,654220561
CVE-2021-40114	0,624100838
CVE-2023-20051	0,489692647

Продолжение таблицы 32

Уязвимость	Значение критичности
CVE-2023-20086	0,720818776
CVE-2024-36927	0,37202421
CVE-2024-56647	0,59046433
CVE-2022-49638	0,46944106
CVE-2023-28981	0,523111762
CVE-2024-47678	0,536383599
CVE-2023-6932	0,57269538
CVE-2021-24074	0,788900959
CVE-2024-1014	0,506625545
CVE-2021-24086	0,729604146
CVE-2024-35857	0,57438549
CVE-2022-41001	0,630519756
CVE-2022-41002	0,732249243
CVE-2020-25705	0,709733618
CVE-2021-24094	0,681350227

В таблице 33 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC – 296.

Таблица 33 – Соотнесение техник и тактик с уязвимостями CAPEC – 296

Шаблон атаки на защищаемую систему	Тактики эксплуатации уязвимостей атакуемой системы	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы
CAPEC-296	Первоначальный доступ	T1190	CVE-2023-20051	0,489692647
			CVE-2024-47678	0,536383599
			CVE-2024-53259	0,54177377
	Закрепление	T1546	CVE-2022-41002	0,732249243
			CVE-2021-24094	0,681350227
		T1574	CVE-2023-6932	0,57269538
	Повышение привилегий	T1068	CVE-2022-0742	0,622168818
			CVE-2022-49638	0,46944106
	Предотвращение обнаружения	T1562	CVE-2023-28981	0,523111762
		T1218	CVE-2024-1014	0,506625545
	Деструктивное воздействие	T1496	CVE-2022-41001	0,630519756
			CVE-2024-35857	0,57438549
			CVE-2024-56647	0,59046433

На рисунке 5 ниже предоставлено графовое изображение множества сценариев реализации атак шаблона CAPEC – 296.

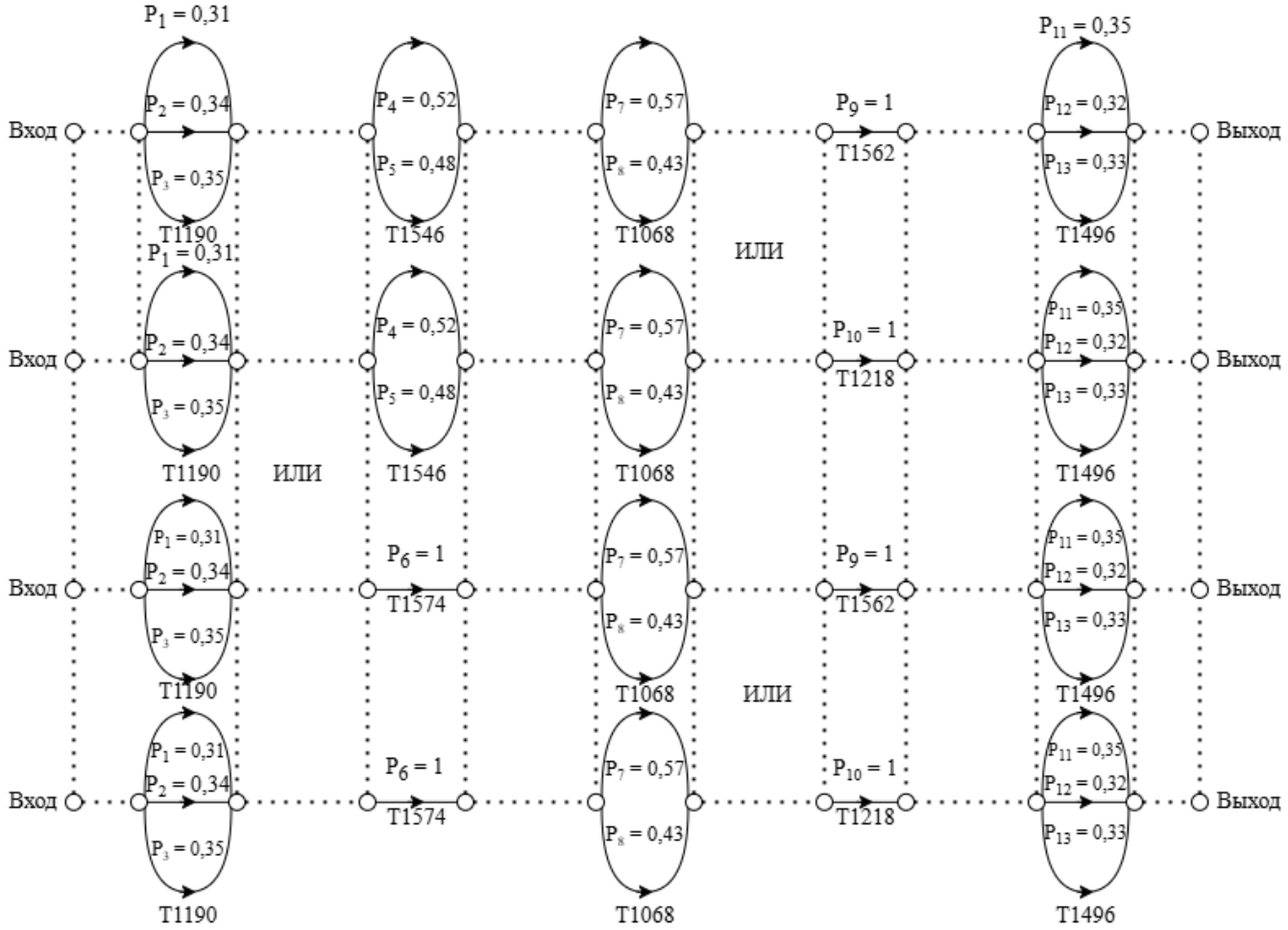


Рисунок 5 – Графовая модель вероятных сценариев реализации шаблона CAPEC – 296

В результате с помощью калькуляторов CVSS 3.0, CVSS 4.0, EPSS и OWASP были оценены уровни критичности уязвимостей и их вероятностей из CAPEC-класса «обнаружение хоста» и построены модели сценариев для выбранных векторов атак.

3.2 Построение микромоделей реализации техник сценариев, учитывающих возможности наступления ущербов, расчет вероятностей успешного использования уязвимостей и рисков успешности реализации различных вариантов сформированных сценариев атак

После определения ключевых сценариев атак, следует проанализировать возможные последствия каждого из них — так называемые подсценарии. Также важно разложить каждый основной сценарий на составляющие микросценарии.

Такой подход позволит выявить наиболее рискованный подсценарий и отразить его в общей структуре основного сценария.

При допущении, что в ходе атаки может быть использована только одна из рассматриваемых уязвимостей, вероятность её успешной реализации определяется следующим образом [7].

$$p_i = \frac{K_i}{\sum_{i=1}^{n} K_i}, \quad (3)$$

где: K_i – критичность i-ой уязвимости.

Для оценки значения ущерба будет использована формула [5,6]:

$$U = 1 - (1 - U\text{к})(1 - U\text{ц})(1 - U\text{д}) , \quad (4)$$

где: Uк — ущерб, связанный с нарушением конфиденциальности;

Uц — ущерб, обусловленный нарушением целостности; Uд — ущерб, вызванный нарушением доступности. Допустимые значения этих показателей [0;0,2;0,5]. Все значения берутся из ресурса CVSS [8], принимающих значение в интервале [0;1].

Полученные значения позволяют определить уровень критичности уязвимости с учётом возможных сценариев её эксплуатации. Риск рассчитывается как произведение вероятности реализации уязвимости Pi на величину потенциального ущерба Ui , связанного с её эксплуатацией. [4].

$$Risk = Pi \times Ui, \quad (5)$$

где: P_i — вероятность эксплуатации уязвимости в рамках микромодели;

U_i — соответствующее значение ущерба от данной уязвимости в микромодели.

Расчет риска всего сценария рассчитывается через формулу, которая учитывает совокупную эксплуатацию всех входящих уязвимостей [9]:

$$RISK_{\Sigma} = \prod_{i=1}^{k} P_i \times \sum_{j=1}^{k} \bar{U}_j, \quad (6)$$

где: P_i — вероятность эксплуатации j-ой уязвимости посредством реализации техники T_i; $\overline{U_j}$ — ущерб, наносимый атакуемой системе в результате эксплуатации уязвимости CVE_j при реализации техники T_i; k – количество используемых техник.

Перейдя к составлению микромоделей сценариев вектора атаки CAPEC-285, предварительно обозначим необходимые формулы для расчётов. В таблицах 34–39 приведены значения вероятностей успешной реализации, возможного ущерба от эксплуатации уязвимостей, а также уровня риска для каждого микрошаблона сценария вектора атаки CAPEC-285, соответствующие иллюстрациям на рисунках 6–10.

Таблица 34 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 1 для сценария CAPEC – 285

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2021-44228	0,334	0,875
2	CVE-2020-5902	0,355	0,875
3	CVE-2017-0144	0,311	0,5

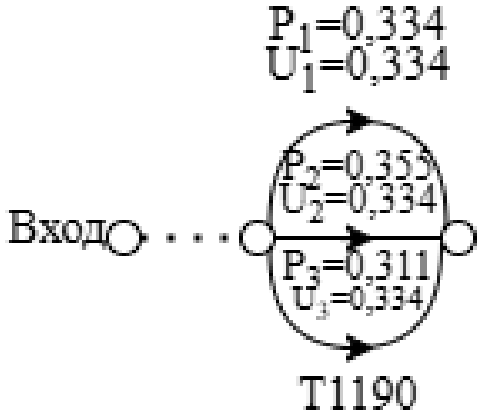


Рисунок 6 – Микромодель 1 (CAPEC – 285)

Таблица 35 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 2 для сценария CAPEC – 285

№	Уязвимость	Вероятность успеха	Ущерб
4	CVE-2020-1472	1	0,875

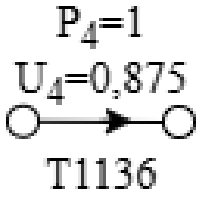


Рисунок 7 – Микромодель 2 (CAPEC – 285)

Таблица 36 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 3 для сценария CAPEC – 285

№	Уязвимость	Вероятность успеха	Ущерб
7	CVE-2017-0144	0,51	0,875
8	CVE-2019-0708	0,49	0,875

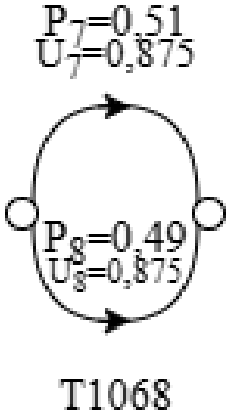


Рисунок 8 – Микромодель 3 (CAPEC – 285)

Таблица 37 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 4 для сценария CAPEC – 285

№	Уязвимость	Вероятность успеха	Ущерб
9	CVE-2017-7494	1	0,875

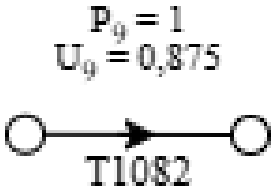


Рисунок 9 – Микромодель 4 (CAPEC – 285)

Таблица 38 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 5 для сценария CAPEC – 285

№	Уязвимость	Вероятность успеха	Ущерб
10	CVE-2019-0708	0,51	0,875
11	CVE-2018-11776	0,49	0,875

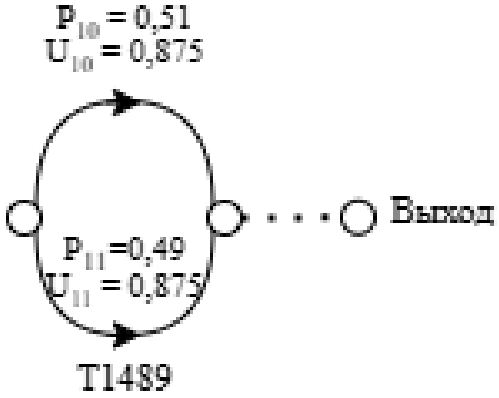


Рисунок 10 – Микромодель 5 (CAPEC - 285)

В результате проведённых расчётов сформированы следующие подсценарии основного сценария вектора атаки CAPEC – 285, представленные на рисунках 11–14.

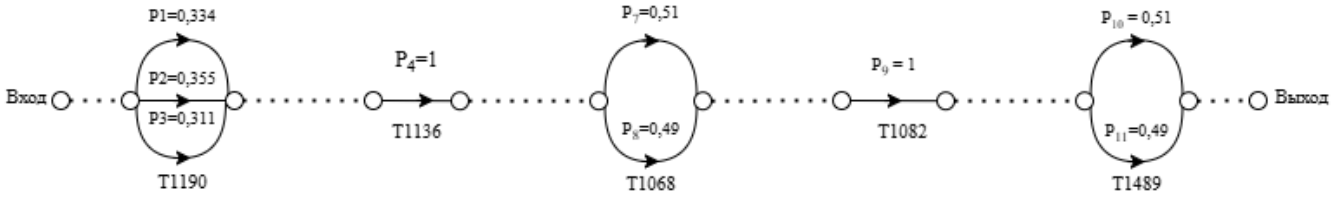


Рисунок 11 – Модель подсценария 1 для CAPEC – 285

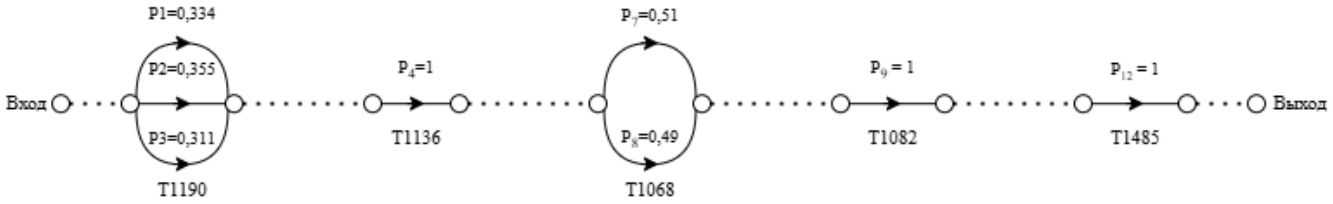


Рисунок 12 – Модель подсценария 2 для CAPEC – 285

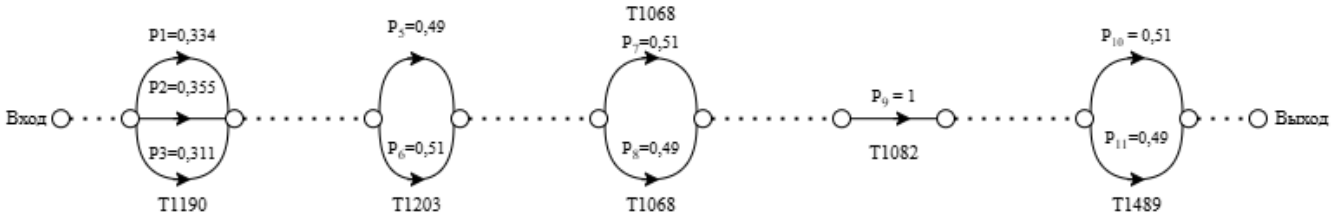


Рисунок 13 – Модель подсценария 3 для CAPEC – 285

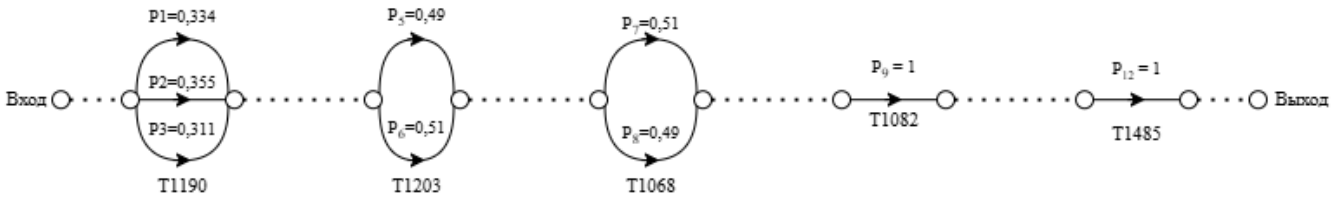


Рисунок 14 – Модель подсценария 4 для CAPEC – 285

Цифрами обозначены следующие уязвимости:

1. CVE-2021-44228
2. CVE-2020-5902
3. CVE-2017-0144
4. CVE-2020-1472
5. CVE-2017-11882

6. CVE-2018-10935
7. CVE-2017-0144
8. CVE-2019-0708
9. CVE-2017-7494
10. CVE-2021-34527
11. CVE-2019-0708
12. CVE-2018-11776

Далее нужно вычислить риски для всех подсценариев. Результаты вычисления для подценариев CAPEC – 285 перечислены ниже в таблице 39.

Таблица 39 – Риски для всех возможных сценариев шаблона CAPEC – 285

Техника (Уязвимости)	Риск
T1190 (CVE-2020-5902) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0.7921
T1190 (CVE-2020-5902) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,761
T1190 (CVE-2021-44228) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,7452
T1190 (CVE-2021-44228) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,716
T1190 (CVE-2017-0144) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,6344
T1190 (CVE-2017-0144) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,6096

Продолжение таблицы 39

Техника (Уязвимости)	Риск
T1190 (CVE-2020-5902) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,404
T1190 (CVE-2020-5902) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,3881
T1190 (CVE-2020-5902) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3881
T1190 (CVE-2020-5902) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,3881
T1190 (CVE-2021-44228) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,3801
T1190 (CVE-2020-5902) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,3729
T1190 (CVE-2020-5902) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3729
T1190 (CVE-2020-5902) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3693
T1190 (CVE-2021-44228) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,3652
T1190 (CVE-2021-44228) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,3652

Продолжение таблицы 39

Техника (Уязвимости)	Риск
T1190 (CVE-2021-44228) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3652
T1190 (CVE-2020-5902) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3549
T1190 (CVE-2021-44228) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,3508
T1190 (CVE-2021-44228) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3508
T1190 (CVE-2021-44228) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3475
T1190 (CVE-2021-44228) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3339
T1190 (CVE-2017-0144) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,3236
T1190 (CVE-2017-0144) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,3109
T1190 (CVE-2017-0144) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,3109
T1190 (CVE-2017-0144) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,3109

Продолжение таблицы 39

Техника (Уязвимости)	Риск
T1190 (CVE-2017-0144) -> T1136 (CVE-2020-1472) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,2987
T1190 (CVE-2017-0144) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,2987
T1190 (CVE-2017-0144) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,2932
T1190 (CVE-2017-0144) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1485 (CVE-2021-34527)	0,2817
T1190 (CVE-2020-5902) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1979
T1190 (CVE-2020-5902) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1902
T1190 (CVE-2020-5902) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1902
T1190 (CVE-2020-5902) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1884
T1190 (CVE-2021-44228) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1862

Продолжение таблицы 39

Техника (Уязвимости)	Риск
T1190 (CVE-2020-5902) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1827
T1190 (CVE-2020-5902) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,181
T1190 (CVE-2020-5902) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,181
T1190 (CVE-2021-44228) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1789
T1190 (CVE-2021-44228) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1789
T1190 (CVE-2021-44228) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1772
T1190 (CVE-2020-5902) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1739
T1190 (CVE-2021-44228) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1719
T1190 (CVE-2021-44228) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1703
T1190 (CVE-2021-44228) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1703

Продолжение таблицы 39

Техника (Уязвимости)	Риск
T1190 (CVE-2021-44228) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1636
T1190 (CVE-2017-0144) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1585
T1190 (CVE-2017-0144) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1523
T1190 (CVE-2017-0144) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1523
T1190 (CVE-2017-0144) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1495
T1190 (CVE-2017-0144) -> T1203 (CVE-2017-11882) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1464
T1190 (CVE-2017-0144) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2017-0144) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,1437
T1190 (CVE-2017-0144) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2019-0708)	0,1437
T1190 (CVE-2017-0144) -> T1203 (CVE-2018-10935) -> T1068 (CVE-2019-0708) -> T1082 (CVE-2017-7494) -> T1489 (CVE-2018-11776)	0,138

По итогам расчетов были обнаружены: путь с максимальным риском; путь с минимальным риском и наиболее вероятный сценарий. Обозначим их на рисунках 15 – 17.

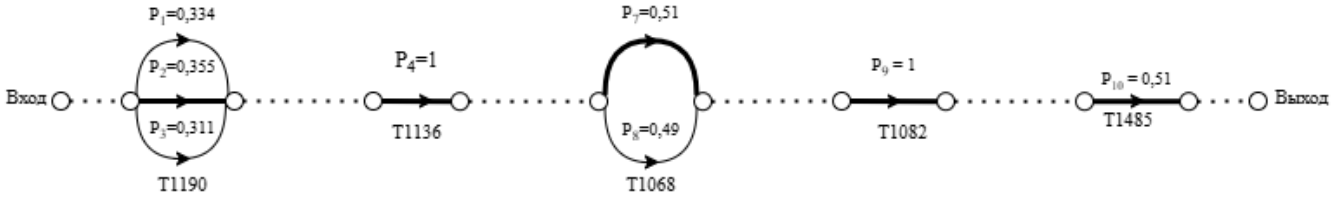


Рисунок 15 – Сценарий шаблона CAPEC – 285 с выделенным максимальным риском

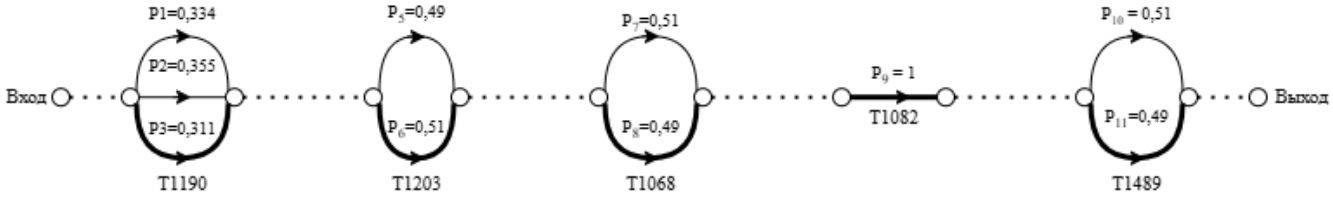


Рисунок 16 – Сценарий шаблона CAPEC – 285 с выделенным минимальным риском

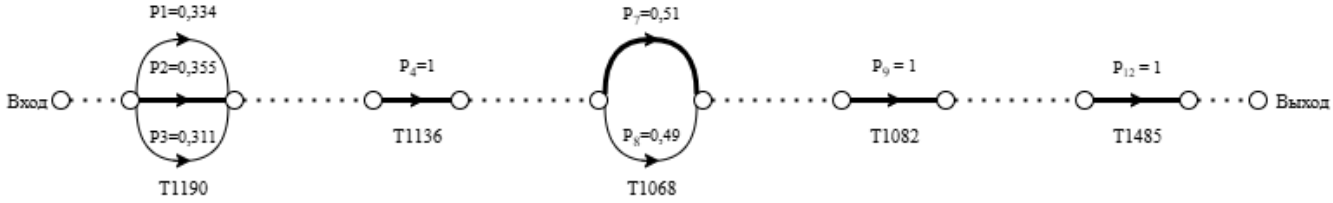


Рисунок 17 – Сценарий шаблона CAPEC – 285 с выделенным наиболее вероятным сценарием

Далее перейдем к составлению микромоделей для шаблона CAPEC – 295. Таблицы 40-45 и рисунки 18-24 ниже обозначают проделанную работу.

Таблица 40 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 1 и 2 для сценария CAPEC – 295

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2025-9876	1	0,75
2	CVE-2016-10161	1	0,5

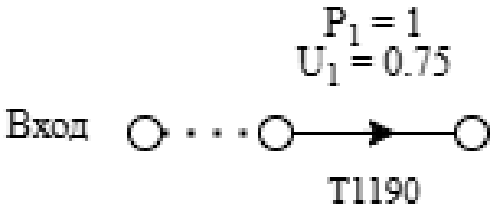


Рисунок 18 – Микромодель 1 (CAPEC – 295)

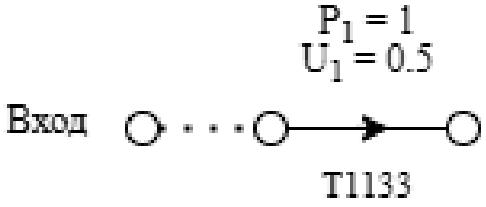


Рисунок 19 – Микромодель 2 (CAPEC – 295)

Таблица 41 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 3 для сценария CAPEC – 295

№	Уязвимость	Вероятность успеха	Ущерб
3	CVE-2020-1350	0,59	0,875
4	CVE-2023-5678	0,41	0,2

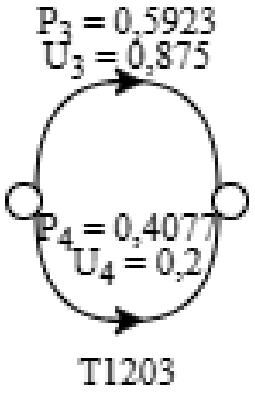


Рисунок 20 – Микромодель 3 (CAPEC – 295)

Таблица 42 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 4 для сценария CAPEC – 295

№	Уязвимость	Вероятность успеха	Ущерб
5	CVE-2025-1357	0,36	0,2
6	CVE-2022-1234	0,29	0,36
7	CVE-2014-7284	0,35	0,2

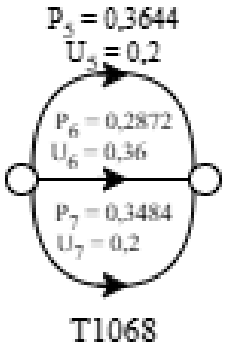


Рисунок 21 – Микромодель 4 (CAPEC – 295)

Таблица 43 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 5 и 6 для сценария CAPEC – 295

№	Уязвимость	Вероятность успеха	Ущерб
8	CVE-2025-12345	1	0,5
9	CVE-2018-12345	1	0,5

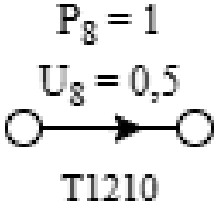


Рисунок 22 – Микромодель 5 (CAPEC – 295)

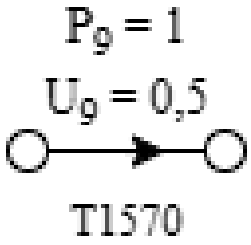


Рисунок 23 – Микромодель 6 (CAPEC – 295)

Таблица 44 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 7 для сценария CAPEC – 295

№	Уязвимость	Вероятность успеха	Ущерб
10	CVE-2023-41354	0,25	0,2
11	CVE-2013-3918	0,42	0,5
12	CVE-2025-23174	0,33	0,5

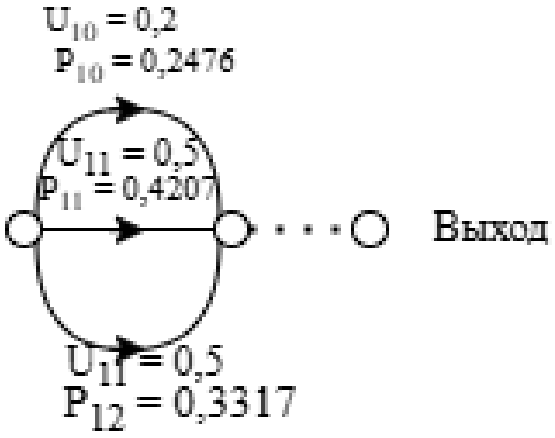


Рисунок 24 – Микромодель 7 (CAPEC – 295)

На основе проведённых расчётов можно выделить следующие подсценарии основного сценария вектора атаки CAPEC – 295, иллюстрируемые на рис. 25–28.

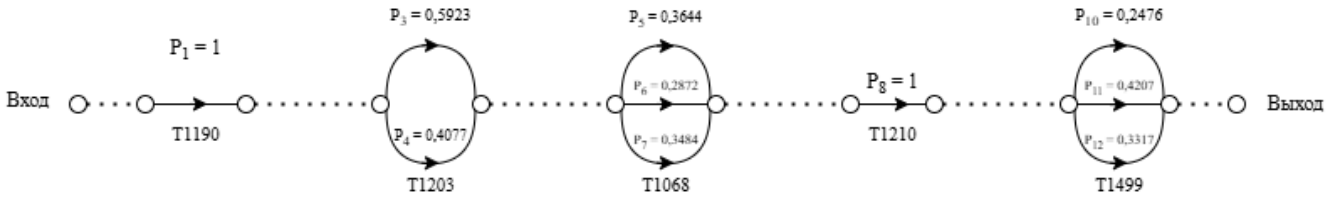


Рисунок 25 – Модель подсценария 1 для CAPEC – 295

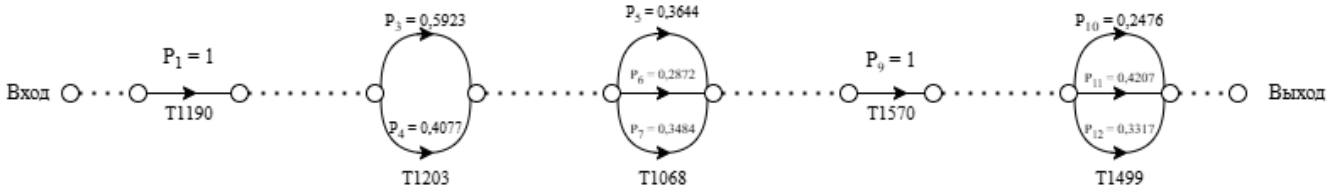


Рисунок 26 – Модель подсценария 2 для CAPEC – 295

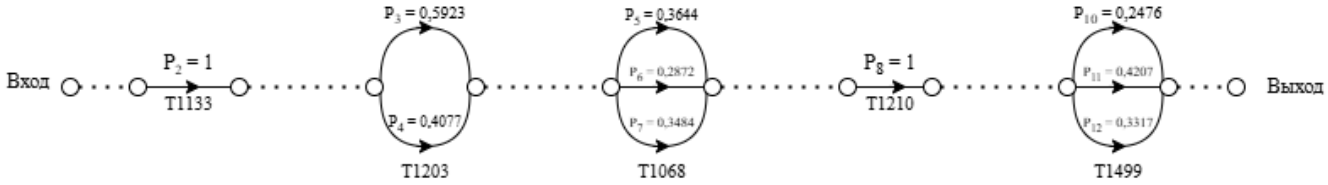


Рисунок 27 – Модель подсценария 3 для CAPEC – 295

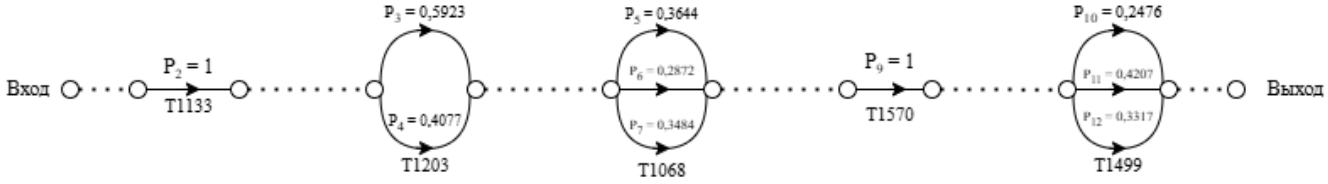


Рисунок 28 – Модель подсценария 4 для CAPEC – 295

Цифрами обозначены следующие уязвимости:

1. CVE-2025-9876
2. CVE-2016-10161
3. CVE-2020-1350
4. CVE-2023-5678

5. CVE-2025-1357
6. CVE-2022-1234
7. CVE-2014-7284
8. CVE-2025-12345
9. CVE-2018-12345
10. CVE-2023-41354
11. CVE-2013-3918
12. CVE-2025-23174

Далее вычислим риски для всех подсценариев. Результаты вычисления для подценариев CAPEC – 295 перечислены ниже в таблице 45.

Таблица 45 - Риски для всех возможных сценариев шаблона CAPEC – 295

Техника (уязвимость)	Риск
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.2520
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.2520
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.2450
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.2450
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.2297
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.2297

Продолжение таблицы 45

Техника (уязвимость)	Риск
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.2233
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.2233
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.2145
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.2145
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1980
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1980
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.1965
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.1965
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1925
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1925

Продолжение таблицы 45

Техника (уязвимость)	Риск
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1805
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1805
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1755
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1755
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1685
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1685
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1544
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1544
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.1356
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.1356

Продолжение таблицы 45

Техника (уязвимость)	Риск
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.1341
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.1341
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.1333
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.1333
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.1304
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.1304
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.1208
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.1208
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.1205
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.1205

Продолжение таблицы 45

Техника (уязвимость)	Риск
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.1178
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.1178
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.1174
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.1174
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.1154
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.1154
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.1149
T1190 (CVE-2025-9876) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.1149
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1065
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1065

Продолжение таблицы 45

Техника (уязвимость)	Риск
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.1047
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.1047
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.1042
T1133 (CVE-2016-10161) ->T1203 (CVE-2020-1350) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.1042
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2013-3918)	0.1029
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2013-3918)	0.1029
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.0947
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.0947
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.0925
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.0925

Продолжение таблицы 45

Техника (уязвимость)	Риск
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.0906
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.0906
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2025-23174)	0.0808
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2025-23174)	0.0808
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.0700
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.0700
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.0683
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.0683
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.0610
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2014-7284) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.0610

Продолжение таблицы 45

Техника (уязвимость)	Риск
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.0597
T1190 (CVE-2025-9876) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.0597
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.0590
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2025-1357) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.0590
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1210 (CVE-2025-12345) ->T1499 (CVE-2023-41354)	0.0523
T1133 (CVE-2016-10161) ->T1203 (CVE-2023-5678) ->T1068 (CVE-2022-1234) ->T1570 (CVE-2018-12345) ->T1499 (CVE-2023-41354)	0.0523

По итогам расчетов были обнаружены: путь с максимальным риском; путь с минимальным риском и наиболее вероятный сценарий. Обозначим их на рисунках 29 – 31.

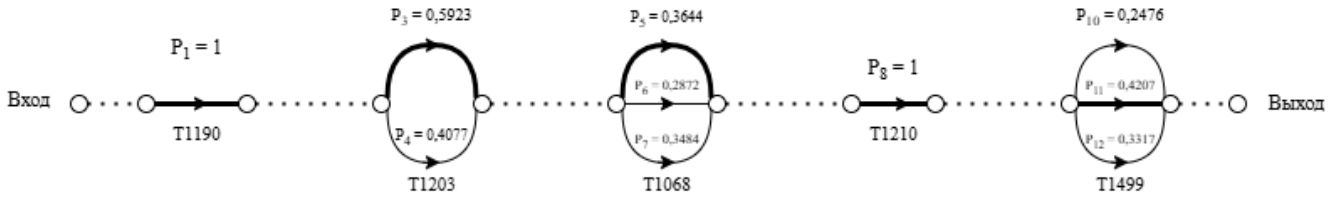


Рисунок 29 – Сценарий шаблона CAPEC – 295 с выделенным максимальным риском

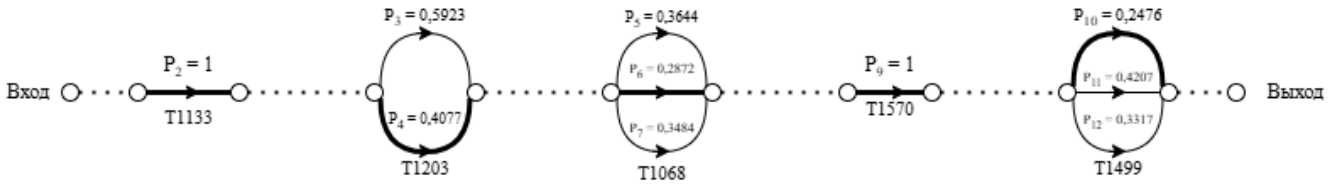


Рисунок 30 – Сценарий шаблона CAPEC – 295 с выделенным минимальным риском

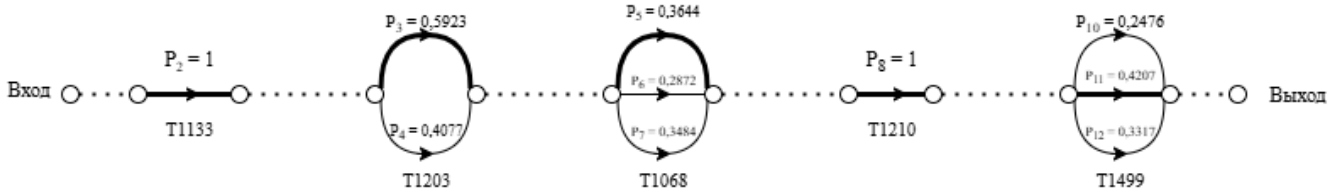


Рисунок 31 – Сценарий шаблона CAPEC – 295 с выделенным наиболее вероятным сценарием

Далее перейдем к составлению микромоделей для шаблона CAPEC – 294. Таблицы 46-51 и рисунки 32-38 ниже обозначают проделанную работу.

Таблица 46 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 1 и 2 для сценария CAPEC – 294

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2022-49633	1	0,5
2	CVE-2023-0386	1	0,875

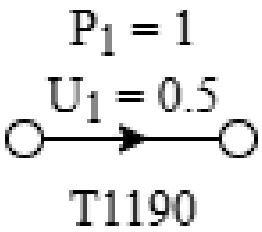


Рисунок 32 – Микромодель 1 (CAPEC – 294)

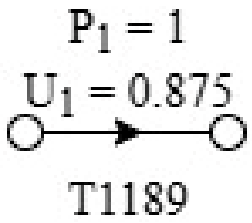


Рисунок 33 – Микромодель 2 (CAPEC – 294)

Таблица 47 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 3 для сценария CAPEC – 294

№	Уязвимость	Вероятность успеха	Ущерб
3	CVE-2023-39540	0,27	0,5
4	CVE-2022-26071	0,37	0,5
5	CVE-2023-6200	0,35	0,875

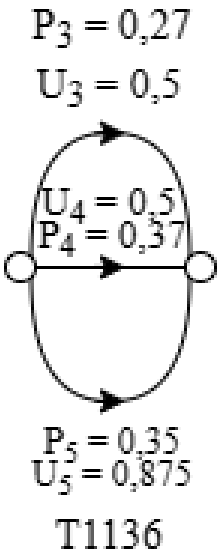


Рисунок 34 – Микромодель 3 (CAPEC – 294)

Таблица 48 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 4 и 5 для сценария CAPEC – 294

№	Уязвимость	Вероятность успеха	Ущерб
6	CVE-2022-49633	1	0,5
7	CVE-2020-16898	1	0,875

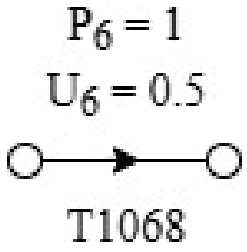


Рисунок 35 – Микромодель 4 (CAPEC – 294)

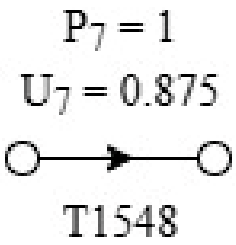


Рисунок 36 – Микромодель 5 (CAPEC - 294)

Таблица 49 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 6 для сценария CAPEC – 294

№	Уязвимость	Вероятность успеха	Ущерб
8	CVE-2022-49632	0,46	0,5
9	CVE-2021-1625	0,54	0,2

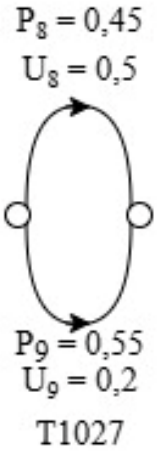


Рисунок 37 – Микромодель 6 (CAPEC - 294)

Таблица 50 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 7 для сценария CAPEC – 294

№	Уязвимость	Вероятность успеха	Ущерб
10	CVE-2021-20322	0,49	0,75
11	CVE-2020-3571	0,51	0,5

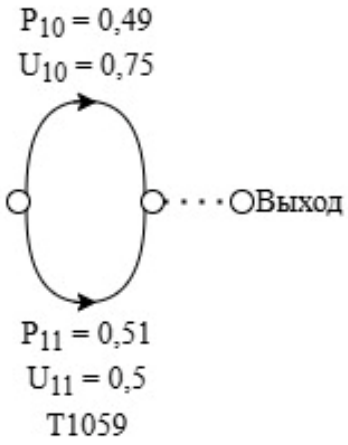


Рисунок 38 – Микромодель 7 (CAPEC – 294)

На основе проведённых расчётов можно выделить следующие подсценарии основного сценария вектора атаки CAPEC – 295, иллюстрируемые на рис. 39–42.

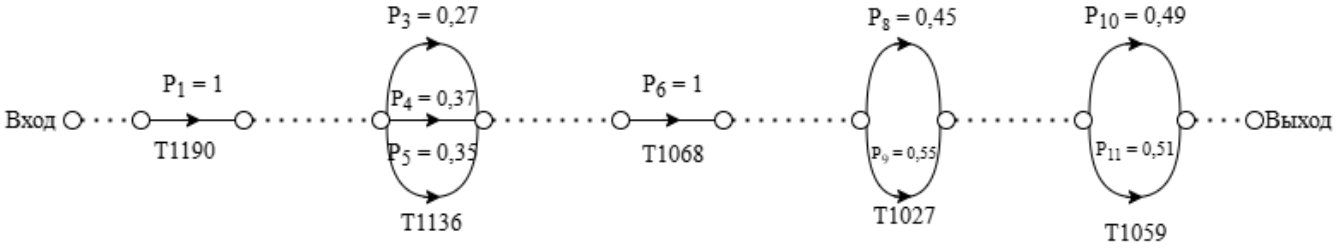


Рисунок 39 – Модель подсценария 1 для CAPEC – 294

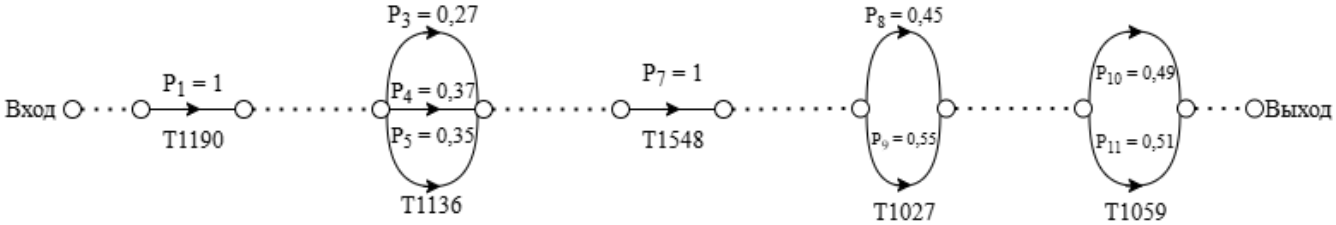


Рисунок 40 – Модель подсценария 2 для CAPEC – 294

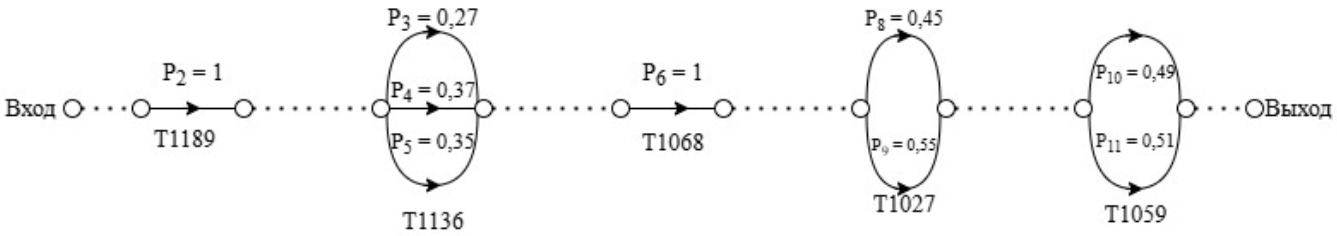


Рисунок 41 – Модель подсценария 3 для CAPEC – 294

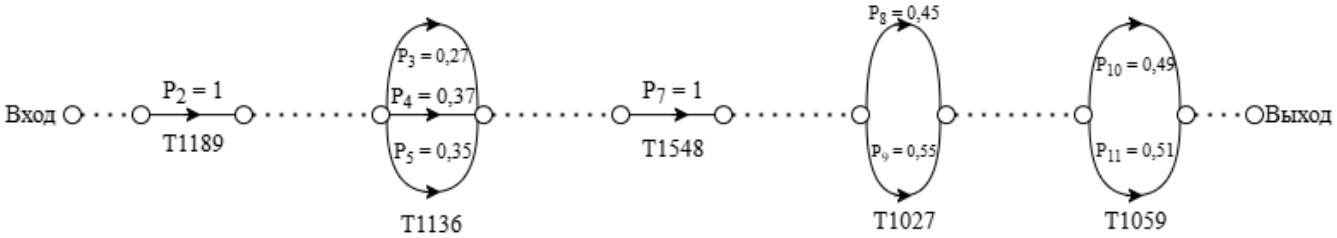


Рисунок 42 – Модель подсценария 1 для CAPEC – 294

Цифрами обозначены следующие уязвимости:

1. CVE-2022-49633
2. CVE-2023-0386
3. CVE-2023-39540
4. CVE-2022-26071
5. CVE-2023-6200
6. CVE-2022-23093
7. CVE-2020-16898
8. CVE-2022-49632
9. CVE-2021-1625
10. CVE-2021-20322
11. CVE-2020-3571

Далее вычислим риски для всех подсценариев. Результаты вычисления для подценариев CAPEC – 294 перечислены ниже в таблице 51.

Таблица 51 - Риски для всех возможных сценариев шаблона CAPEC – 294

Техника (уязвимость)	Риск
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.3372
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.3264
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.3191
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.3062
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.3018
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.3018
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2991
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2912
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.2896
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.2896
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2855

Продолжение таблицы 51

Техника (уязвимость)	Риск
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.2817
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.2817
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2760
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2701
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2701
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.2672
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.2672
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.2665
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2611
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2611
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2550

Продолжение таблицы 51

Техника (уязвимость)	Риск
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2550
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.2528
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.2443
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2441
T1189 (CVE-2023-0386) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2441
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2412
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.2328
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-6200) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2309
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.2283
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2244
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.2234

Продолжение таблица 51

Техника (уязвимость)	Риск
T1190 (CVE-2022-49633) ->T1136 (CVE-2022-26071) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2123
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.2084
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.2056
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.2056
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.2014
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.1950
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.1950
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.1860
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.1860
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2021-20322)	0.1783

Продолжение таблицы 51

Техника (уязвимость)	Риск
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1548 (CVE-2020-16898) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.1781
T1189 (CVE-2023-0386) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.1781
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2021-1625) ->T1059 (CVE-2020-3571)	0.1666
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2021-20322)	0.1637
T1190 (CVE-2022-49633) ->T1136 (CVE-2023-39540) ->T1068 (CVE-2022-23093) ->T1027 (CVE-2022-49632) ->T1059 (CVE-2020-3571)	0.1549

По итогам расчетов были обнаружены: путь с максимальным риском; путь с минимальным риском и наиболее вероятным сценарием. Обозначим их на рисунках 43 – 45.

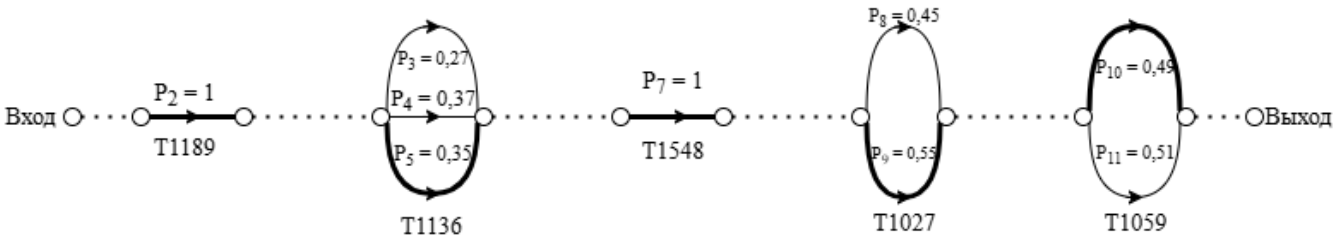


Рисунок 43 – Сценарий шаблона CAPEC – 294 с выделенным максимальным риском

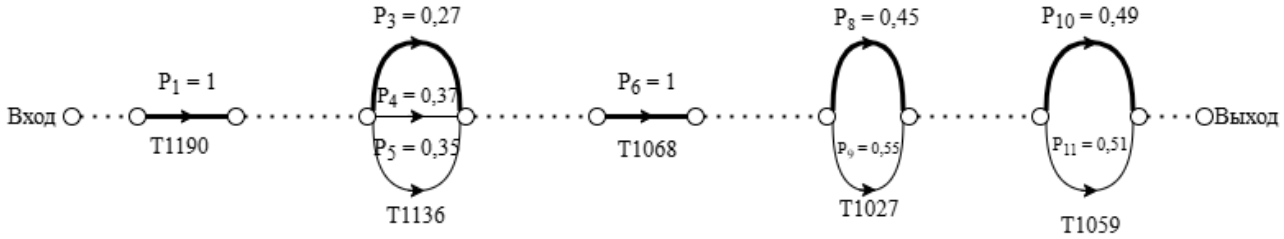


Рисунок 44 – Сценарий шаблона CAPEC – 294 с выделенным минимальным риском

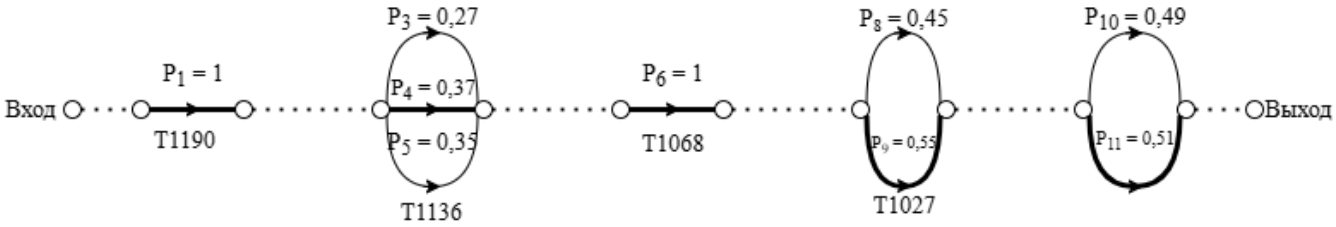


Рисунок 45 – Сценарий шаблона CAPEC – 294 с выделенным наиболее вероятным сценарием

Далее перейдем к составлению микромоделей для шаблона CAPEC – 296. Таблицы 52-57 и рисунки 46-52 ниже обозначают проделанную работу.

Таблица 52 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 1 для сценария CAPEC – 296

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2023-20051	0,31	0,5
2	CVE-2024-47678	0,34	0,5
3	CVE-2024-53259	0,35	0,5

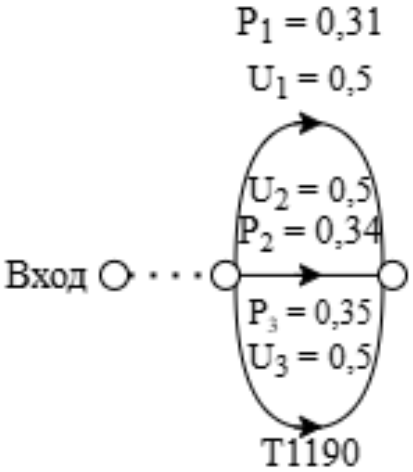


Рисунок 46 – Микромодель 1 (CAPEC 296)

Таблица 53 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 2 и 3 для сценария CAPEC – 296

№	Уязвимость	Вероятность успеха	Ущерб
4	CVE-2022-41002	0,52	0,875
5	CVE-2021-24094	0,48	0,875
6	CVE-2023-6932	1	0,875

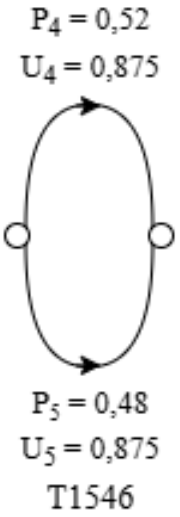


Рисунок 47 – Микромодель 2 (CAPEC 296)

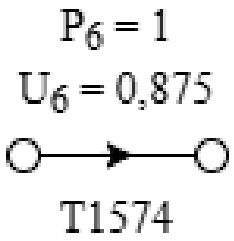


Рисунок 48 – Микромодель 3 (CAPEC 296)

Таблица 54 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 4 для сценария CAPEC – 296

№	Уязвимость	Вероятность успеха	Ущерб
7	CVE-2022-0742	0,57	0,5
8	CVE-2022-49638	0,43	0,5

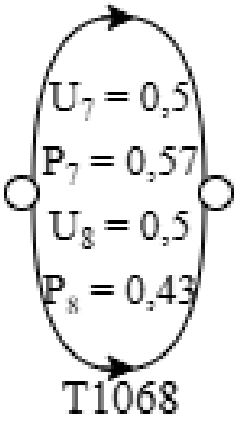


Рисунок 49 – Микромодель 4 (CAPEC - 296)

Таблица 55 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 5 и 6 для сценария CAPEC – 296

№	Уязвимость	Вероятность успеха	Ущерб
9	CVE-2023-28981	1	0,5
10	CVE-2024-1014	1	0,5

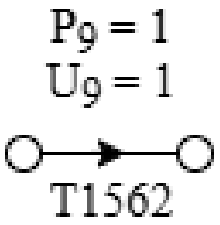


Рисунок 50 – Микромодель 5 (CAPEC 296)

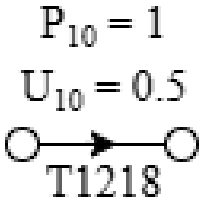


Рисунок 51 – Микромодель 6 (CAPEC 296)

Таблица 56 – Вероятность эксплуатации единичной уязвимости и ущерба для микромодели 7 для сценария CAPEC – 296

№	Уязвимость	Вероятность успеха	Ущерб
11	CVE-2022-41002	0,35	0,875
12	CVE-2021-24094	0,32	0,2
13	CVE-2023-6932	0,33	0,2

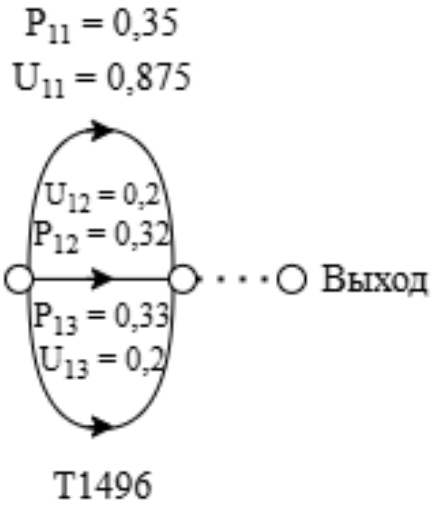


Рисунок 52 – Микромодель 7 (CAPEC 296)

На основе проведённых расчётов можно выделить следующие подсценарии основного сценария вектора атаки CAPEC – 296, иллюстрируемые на рис. 53–56.

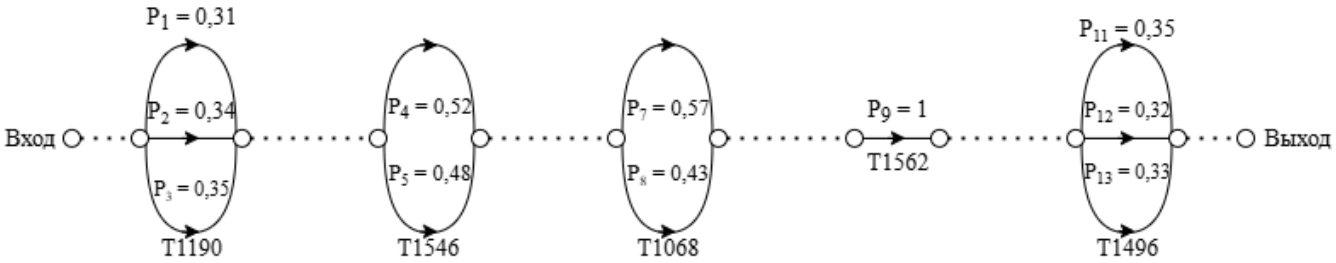


Рисунок 53 – Модель подсценария 1 для CAPEC – 296

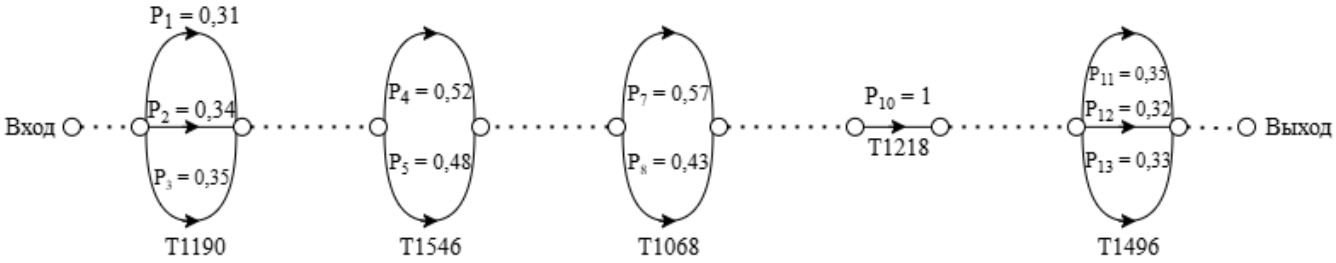


Рисунок 54 – Модель подсценария 2 для CAPEC – 296

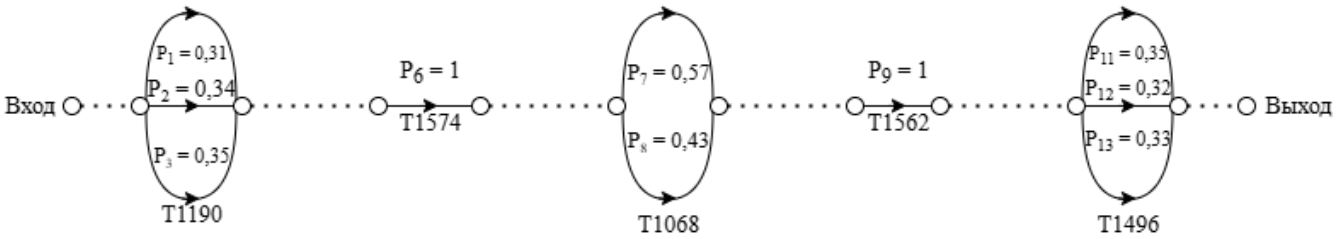


Рисунок 55 – Модель подсценария 3 для CAPEC – 296

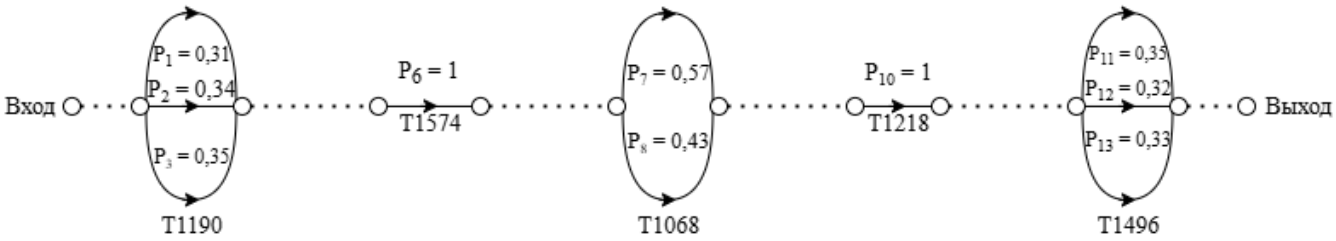


Рисунок 56 – Модель подсценария 4 для CAPEC – 296

Цифрами обозначены следующие уязвимости:

1. CVE-2023-20051
2. CVE-2024-47678
3. CVE-2024-53259

4. CVE-2022-41002
5. CVE-2021-24094
6. CVE-2023-6932
7. CVE-2022-0742
8. CVE-2022-49638
9. CVE-2023-28981
10. CVE-2024-1014
11. CVE-2022-41001
12. CVE-2024-35857
13. CVE-2024-56647

Далее вычислим риски для всех подсценариев. Результаты вычисления для подценариев CAPEC – 296 перечислены ниже в таблице 57.

Таблица 57 - Риски для всех возможных сценариев шаблона CAPEC – 296

Техника (Уязвимость)	Риск
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.2269
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.2269
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.2204
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.2204
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.2010
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.2010
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.1893
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.1893
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.1839

Продолжение таблицы 57

Техника (Уязвимость)	Риск
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.1839
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1712
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1712
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.1676
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.1676
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1663
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1663
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.1644
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.1644
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.1597
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.1597
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1516
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1516
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.1456
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.1456
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.1428
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.1428
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.1387

Продолжение таблицы 57

Техника (Уязвимость)	Риск
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.1387
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.1265
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.1265
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.1240
T1190 (CVE-2024-53259) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.1240
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.1205
T1190 (CVE-2024-47678) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.1205
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1180
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1180
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1146
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1146
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.1098
T1190 (CVE-2023-20051) -> T1574 (CVE-2023-6932) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.1098
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1089
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1089
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1058
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1058
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.1045

Продолжение таблицы 57

Техника (Уязвимость)	Риск
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.1045
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0984
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0984
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.0965
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.0965
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0956
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0956
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0909
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0909
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.0890
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.0890
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0883
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0883
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0872
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0872
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.0865
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.0865
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0855

Продолжение таблицы 57

Техника (Уязвимость)	Риск
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0855
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0830
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0830
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.0822
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.0822
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0805
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0805
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.0798
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.0798
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0789
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0789
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.0788
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.0788
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0767
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0767
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0757
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0757
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0742

Продолжение таблицы 57

Техника (уязвимость)	Риск
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0742
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2022-41001)	0.0728
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2022-41001)	0.0728
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0721
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0721
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0699
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-0742) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0699
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0685
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0685
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0666
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0666
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0658
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0658
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0645
T1190 (CVE-2024-53259) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0645
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0626
T1190 (CVE-2024-47678) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0626

Продолжение таблицы 57

Техника (уязвимость)	Риск
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-56647)	0.0607
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-56647)	0.0607
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0595
T1190 (CVE-2024-53259) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0595
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0578
T1190 (CVE-2024-47678) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0578
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0571
T1190 (CVE-2023-20051) -> T1546 (CVE-2022-41002) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0571
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1562 (CVE-2023-28981) -> T1496 (CVE-2024-35857)	0.0527
T1190 (CVE-2023-20051) -> T1546 (CVE-2021-24094) -> T1068 (CVE-2022-496385) -> T1218 (CVE-2024-1014) -> T1496 (CVE-2024-35857)	0.0527

По итогам расчетов были обнаружены: путь с максимальным риском; путь с минимальным риском и наиболее вероятным маршрутом. Обозначим их на рисунках 57 – 59.

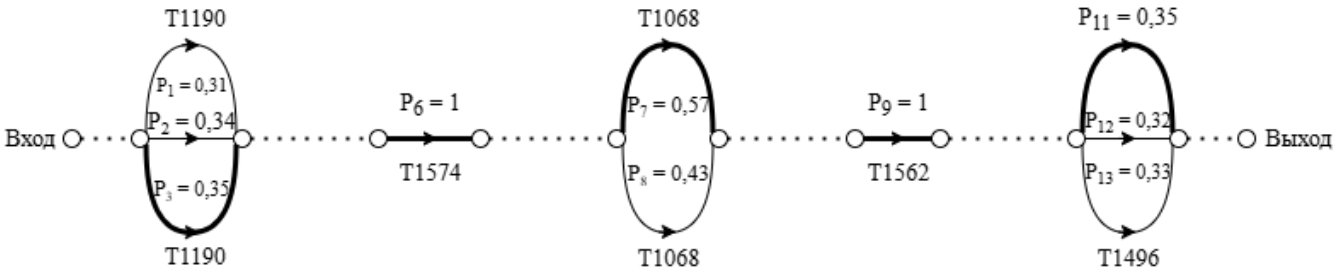


Рисунок 57 – Сценарий шаблона CAPEC – 296 с выделенным максимальным риском

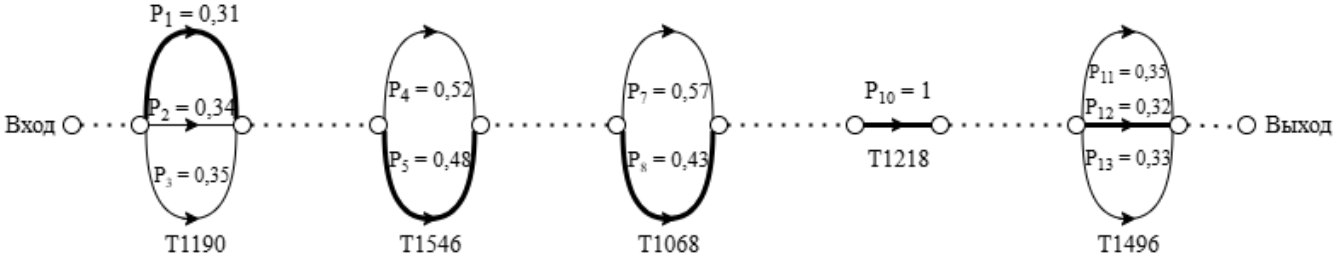


Рисунок 58 – Сценарий шаблона CAPEC – 296 с выделенным минимальным риском

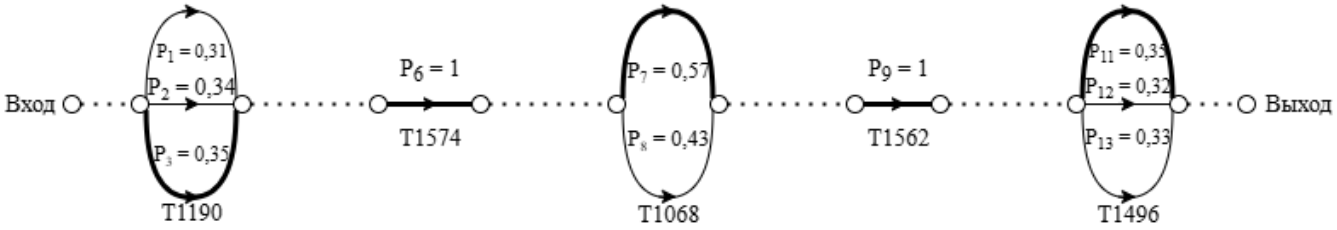


Рисунок 59 – Сценарий шаблона CAPEC – 296 с выделенным наиболее вероятным сценарием

4 Разработка организационно-правовых регламентов, снижающих риски реализации предложенных сценариев атак, заданных шаблонов

Помимо первостепенной задачи прогнозирования вероятных шагов злоумышленников, готовящих атаку на автоматизированную информационную систему, эксперты по кибербезопасности обязаны заниматься созданием и внедрением результативных мер по пресечению различных типов атак. Особое значение в этом аспекте приобретают атаки, использующие привилегии для достижения цели, так как они причисляются к категории наиболее критичных и сложных для выявления.

В данной главе предполагается разработка комплекса организационно-правовых нормативов, нацеленных на уменьшение вероятности проведения таких атак. Данные регламенты будут сформированы с учетом предварительно рассмотренных сценариев атак и разделены по стадиям, соответствующим классификации MITRE. Для каждого этапа сценария атаки предполагается:

— регистрируемые инциденты — описание событий, представляющих угрозу и подлежащих фиксации как потенциальные инциденты информационной безопасности;

— меры реагирования — конкретные действия по локализации, сдерживанию или пресечению атаки при её обнаружении;

— меры устранения последствий — действия, направленные на минимизацию ущерба и восстановление нормального функционирования информационных систем.

Данная схема обеспечивает возможность упорядочить действия при возникновении инцидентов, что способствует повышению уровня безопасности корпоративной инфраструктуры.

4.1 Разработка организационно-правовых регламентов, для CAPEC – 285

Ниже в таблице 58 приведены результаты разработки регламентов для шаблона атаки CAPEC – 285.

Таблица 58 - Организационно-правовой регламент шаблона атаки CAPEC-285

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Зафиксированы попытки атаки на публично доступное веб-приложение, использующей уязвимость CVE-2020-5902 в компоненте F5 BIG-IP. Уязвимость позволяет выполнять команды удалённо без аутентификации, что свидетельствует об использовании техники T1190 (Exploit Public-Facing Application).	1.Заблокировать сетевой доступ к уязвимому узлу: ufw deny <source_IP> или настройка фильтрации на WAF. 2.Завершить текущие сеансы и обрывать соединения с атакующего IP: tcpkill, ss, netstat. 3.Активировать внутренний плейбук реагирования на эксплуатацию внешнего веб-приложения (T1190), уведомить SOC.	1.Провести анализ логов access.log на признаки выполнения команд через интерфейс /mgmt/tm/util/bash (grep, fail2ban). 2.Изолировать актив на уровне хоста или сегмента через iptables или Egress filtering. 3.Выполнить патчинг: установка обновления безопасности для F5 BIG-IP через tmsh install sys software. Провести аудит на внедрение постэксплуатационных компонентов.

Продолжение таблицы 58

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Закрепление	Обнаружено несанкционированное создание учетных записей с административными правами в доменной среде, связанное с эксплуатацией уязвимости CVE-2020-1472 (Zerologon), что указывает на применение техники T1136 (Create Account).	1.Проверить журналы безопасности Windows на создание новых учётных записей (Event ID 4720, 4722). 2.Деактивировать подозрительные учетные записи: net user /active:no, Set-ADUser -Enabled $false. 3.Прекратить активность атакующего: отключить узел в AD, сбросить доверие канала: nltest /SC_RESET.	1.Удалить аномальные учётные записи: net user <user> /del, очистить группы Domain Admins от посторонних. 2.Применить исправление CVE-2020-1472 (KB4578013). 3.Провести проверку на возможную реверсивную подгрузку политик и перепривязку DC. Усилить мониторинг событий безопасности.

Продолжение таблицы 58

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привелегий	Зафиксировано применение эксплойта EternalBlue, использующего уязвимость CVE-2017-0144 для повышения привилегий в системе и перехода на уровень администратора. Атака соответствует технике T1068 (Exploitation for Privilege Escalation).	1.Немедленно отключить SMBv1: Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol. 2.Заблокировать трафик на порту TCP/445 (локально и на шлюзах): ufw, firewalld. 3.Провести сетевой мониторинг и инвентаризацию активных сессий с помощью netstat, Wireshark, Zeek.	1. Выполнить анализ событий 4673/4674 в журналах безопасности Windows для выявления несанкционированного повышения привилегий. 2.Провести централизованное обновление Windows систем через WSUS или SCCM, закрывающее уязвимость CVE-2017-0144. 3.В случае компрометации — восстановить систему из резервной копии. Усилить мониторинг PowerShell и WMI.

Продолжение таблицы 58

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Предотвращение обнаружения	Атакующий получил возможность просматривать сведения о системе через удаленный доступ к Samba с использованием уязвимости CVE-2017-7494. Это свидетельствует о применении техники T1082 (System Information Discovery), направленной на сокрытие присутствия в системе и сбор данных о ней.	1.Выгрузить и остановить службы Samba: systemctl stop smbd nmbd, отключить автозапуск. 2.Включить аудит системных вызовов: auditctl, auditd с фильтрацией по execve. 3.Проанализировать конфигурации Samba на наличие сторонних включений, осуществить контроль доступов к /tmp, /var/tmp.	1.Сканировать систему на скрытые процессы и аномальную активность: chkrootkit, rkhunter, lynis. 2. Верифицировать бинарные файлы Samba (md5sum), пересоздать конфигурации из эталона (бекап). 3. Ограничить доступ к службе по IP и сегменту сети, установить фильтрацию трафика через iptables или firewalld.

Продолжение таблицы 58

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Деструктивное воздействие	Зафиксировано использование уязвимости PrintNightmare (CVE-2021-34527), позволяющей атакующему удаленно выполнять команды и удалять критические файлы. Атака классифицируется по технике T1485 (Data Destruction).	1.Немедленно остановить службу диспетчера очереди печати: Stop-Service Spooler и отключить автозапуск через GPO. 2. Выгрузить события удаления и изменения объектов: wevtutil, Event ID 4663. 3.Инициировать процедуру отключения хоста от сети при обнаружении активного удаления данных.	1.Выполнить восстановление удалённых данных из резервных копий (wbadmin, Veeam, Acronis и др.). 2.Установить патч безопасности: KB5004945 (защита от PrintNightmare). 3.Проверить и очистить реестр и политики доступа к печати, исключить возможность удалённой печати для всех групп, кроме доверенных.

4.2 Разработка организационно-правовых регламентов, для CAPEC – 295

Ниже в таблице 59 приведены результаты разработки регламентов для шаблона атаки CAPEC – 295.

Таблица 59 - Организационно-правовой регламент шаблона атаки CAPEC-295

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Обнаружен внешний доступ к уязвимому веб-приложению через CVE-2025-9876. Зафиксированы аномальные HTTP-запросы с внедрением SQL/OS команд. Использована техника T1190 – Exploit Public-Facing Applicatio	1. Блокировка IP-адреса через WAF или ufw deny <source_IP>. 2.Завершение активных соединений через tcpkill, nginx reload. 3.Аудит логов: grep POST /admin в access.log.	1.Изоляция уязвимого веб-приложения из DMZ. 2.Применение патча CVE-2025-9876, перезапуск службы. 3.Контрольный аудит уязвимости: Nikto, OWASP ZAP. 4.Проверка целостности: сравнение хеша исполняемых файлов.

Продолжение таблицы 59

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Закрепление	Зафиксирован запуск эксплойта SIGRed через вредоносный запрос. Возможность удалённого исполнения кода CVE-2020-1350, без взаимодействия с пользователем. Использована техника T1203 – Exploitation for Client Execution.	1.Выгрузка службы DNS: taskkill /PID <pid>. 2. Проверка логов: Event ID 1014 (DNS Client Errors). 3.Мониторинг сетевого трафика на длинные DNS-запросы. 4.Перевод заражённого узла в изолированную зону.	1. Патч по CVE-2020-1350 (KB4569509) 2. Перезапуск DNS: Restart-Service -Name DNS. 3.Установка ограничения recursion limit = 0xFF. 4. Проверка кэша DNS и сброс резольверов.

Продолжение таблицы 59

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привелегий	Обнаружена попытка использования прав администратора через локальный эксплойт ядра Windows. Признаки повышения привилегий с использованием техники T1068 – Exploitation for Privilege Escalation.	1. Включение аудита прав: auditpol /set /subcategory:"Privilege Use". 2.Поиск schtasks, token impersonation, sc create. 3.Блокировка неизвестных служб и задач.	1.Установка патча CVE-2025-1357. 2. Целостностный контроль: sfc /scannow, sigcheck. 3. Перенастройка GPO/ACL.. 4. Проверка на руткиты: GMER, rkhunte.

Продолжение таблицы 59

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Предотвращение обнаружения	Зафиксировано подключение к доверенной системе через уязвимость CVE-2025-12345 в службе удалённого доступа (например, SSH, NFS). Использована техника T1210 – Exploitation of Remote Services.	1.Отслеживание логинов через last, auditd, journalctl. 2. Завершение сессий: pkill -KILL -u <user>. 3. Блокировка порта: iptables -A INPUT -p tcp --dport 22 -j DROP.	1. Установка патча на SSH/NFS (по CVE). 2. Удаление чужих SSH-ключей, пересоздание ~/.ssh. 3. Аудит: nmap, netstat, очистка .bash_history. 4. Сброс паролей и ротация ключей.

Продолжение таблицы 59

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Деструктивное воздействие	В системных логах зафиксирован резкий рост потребления ресурсов. Использован DoS-эксплойт для WMI (Windows Management Instrumentation). Применена техника T1499 – Endpoint Denial of Service.	1.Диагностика нагрузки: perfmon, top, htop. 2.Ограничение CPU/трафика: tc, iptables, QoS. 3.Блокировка атакующего источника: fail2ban, WAF. 4.Снятие дампов: tcpdump, dumpcap.	1. Применение патча (KB2862152) от CVE-2013-3918. 2.Перезапуск winmgmt или WMI service. 3.Планирование миграции сервисов на отказоустойчивую платформу. 4.Настройка предельной нагрузки и мониторинга с порогами тревоги.

4.3 Разработка организационно-правовых регламентов, для CAPEC – 294

Ниже в таблице 60 приведены результаты разработки регламентов для шаблона атаки CAPEC – 294.

Таблица 60 - Организационно-правовой регламент шаблона атаки CAPEC-294

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Зафиксировано открытие вредоносной ссылки пользователем с переходом на веб-ресурс, эксплуатирующий уязвимость CVE-2023-0386 в overlayfs (Linux). Загружен и выполнен вредоносный payload без привилегий. Использована техника T1189 – Drive-by Compromise.	1.Изолировать рабочую станцию из пользовательского сегмента 2.Выгрузить сессию пользователя, остановить процессы браузера 3.Проверить временные каталоги /tmp, /dev/shm, /run/user на исполняемые объекты 4. Активировать внутренний инцидент-плейбук T1189	1.Удалить загруженные файлы, проверить наличие суффиксов .so, .ko, .sh 2. Обновить ядро и модули overlayfs до версии с патчем (через apt upgrade, yum update, dnf) 3.Провести анализ активности через auditd, strace, journalctl 4.Включить AppArmor/SELinux политики для ограничения overlayfs

Продолжение таблицы 60

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Закрепление	Выявлено несанкционированное создание нового системного пользователя через уязвимость в PAM-модуле (CVE-2023-6200). Атакующий получил доступ к оболочке через sudo. Использована техника T1136 – Create Account.	1.Проверка /etc/passwd, /etc/shadow на появление новых записей 2.Деактивация или удаление новой учётной записи: usermod -L, userdel -r 3.Аудит логов auth.log, secure, pam.d 4.Оповещение SOC и эскалация по инциденту	1.Применить патч или обновление PAM, закрывающее CVE-2023-6200 2.Провести опрос целевой системы на наличие бекдоров (/home/.config, .bashrc, cron) 3.Очистить записи SSH authorized_keys 4.Обновить правила sudoers, ограничить группу wheel

Продолжение таблицы 60

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привелегий	Обнаружена эксплуатация уязвимости CVE-2020-16898 (Bad Neighbor) для эскалации прав через подделку ICMPv6 Router Advertisement.	1.Заблокировать ICMPv6: netsh interface ipv6 set icmpredirects admin=disable 2.Проверка активности через Wireshark, tcpdump icmp6 3.Изоляция хоста от локальной сети	1.Применить патч KB4579646, устраняющий CVE-2020-16898 2.Перезапуск сетевого стека: ipconfig /release, renew, FlushDNS 3.Очистить маршруты и перезапустить IPv6 интерфейс 4.Включить ND filtering, RA Guard на L2 уровне

Продолжение таблицы 60

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Предотвращение обнаружения	Зафиксировано внедрение зашифрованного исполняемого кода с использованием полиморфного пакера и уязвимости CVE-2021-1625 (в Windows Print Spooler), что позволяет скрыть запуск вредоносного драйвера. Использована техника	1.Сканирование памяти: Volatility, procmon, PE-sieve 2.Идентификация аномальных DLL/EXE: sigcheck, hashdeep, Autoruns 3.Отключение Spooler: sc stop spooler && sc config spooler start=disabled 4.Распаковка бинарников для анализа	1.Применить патч безопасности (KB5004945) по CVE-2021-1625 2.Удаление всех временных .spl, .shd файлов из %systemroot%\System32\spoo 3.Отключение Spooler: sc stop spooler && sc config spooler start=disabled

Продолжение таблицы 60

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Деструктивное воздействие	Выявлено выполнение команд через оболочку Bash в Linux по уязвимости CVE-2021-20322 (уязвимость в stdin в systemd). Запущены скрипты на Bash с payload через stdin-подмену.	1.Выполнить мониторинг процессов с фильтрацией по оболочке: `ps aux	1.Отключить stdin piping в systemd юнитах 3. 2.Изоляция узла с заражённым systemd-модулем 4.Проверка journalctl -u, systemctl cat` на подмену скриптов

4.4 Разработка организационно-правовых регламентов, для CAPEC – 296

Ниже в таблице 61 приведены результаты разработки регламентов для шаблона атаки CAPEC – 296.

Таблица 61 - Организационно-правовой регламент шаблона атаки CAPEC-296

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Первоначальный доступ	Атака через CVE-2024-53259 — удалённое выполнение кода на сервере приложений через YAML-инъекцию. Использована техника T1190 – Exploit Public-Facing Application.	1.Заблокировать атакующий IP через iptables, ufw, или WAF. 2.Изолировать сервер из сети: VLAN quarantine или firewall zone drop. 3. Выполнить анализ логов на шаблоны YAML-инъекций: `grep -E '(!!	1. Установить обновление фреймворка/библиотеки YAML (например, PyYAML, js-yaml) до безопасной версии. 2. Пересобрать уязвимые контейнеры или перекатить приложение через CI/CD pipeline с безопасной зависимостью. 3. Очистить временные директории (/tmp, /var/tmp, /dev/shm) от внедрённых файлов. 4. Сканировать весь хост на артефакты post-exploitation: rkhunter, chkrootkit, clamscan. 5. Провести контрольную проверку через веб-сканеры (ZAP, Nikto, Nexpose).

Продолжение таблицы 61

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Закрепление	Зафиксирована подмена системной библиотеки через подгрузку libc.so или ntdll.dll в нестандартных путях (CVE-2023-6932). Использована техника T1574 – Hijack Execution Flow	1.Проверить переменные окружения: env, printenv, %PATH%, LD_PRELOAD. 2. Выполнить поиск загруженных библиотек: `lsof	1.Удалить подменённые библиотеки из LD_LIBRARY_PATH, %PATH%, AppData\Temp или /tmp. 2.Восстановить оригинальные системные библиотеки из доверенных источников (sfc /scannow, rpm -V, apt reinstall конкретного пакета). 3.Настроить цифровую подпись и верификацию: Windows Defender Application Control, AppArmor, SELinux. 4.Провести пересборку уязвимых бинарников/приложений, исключив возможность загрузки из пользовательских путей.

Продолжение таблицы 61

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Повышение привелегий	Установлен факт эксплуатации CVE-2022-0742 — локальной уязвимости в polkit (pkexec), позволяющей выполнить команду от root.	1.Проверить права доступа к pkexec: ls -l /usr/bin/pkexec. 2. Выполнить find / -perm -4000 -type f на поиск SUID-файлов. 3. Аудит: ausearch -x pkexec, journalctl -xe, auditctl на execve. 4.Временно ограничить доступ: chmod 750 /usr/bin/pkexec. 5.Выгрузить список root-процессов: `ps -eo euser,pid,cmd	1. Обновить polkit до версии, закрывающей CVE-2022-0742 (apt, yum, dnf). 2. Ограничить доступ к pkexec: изменить права, удалить вызовы из sudoers, запретить через AppArmor/SELinux профили. 3. Проверить группу sudo, wheel, admin на наличие неавторизованных пользователей и удалить их. 4. Провести аудит setuid файлов и восстановить стандартные права: dpkg --verify, rpm -Va, restorecon.

Продолжение таблицы 61

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Предотвращение обнаружения	Атакующий отключил защиту ядра/AV средствами, используя CVE-2023-28981 — обход античит/EDR за счёт подмены kernel-mode драйвера.	1.Проверить службы: sc query, systemctl list-units. 2.Проверить наличие вредоносных драйверов: driverquery, lsmod, fltmc. 3.Аудит автозагрузки: schtasks /query, autoruns, cron. 4.Выгрузка событий из Windows Logs: Security.evtx, System.evtx. 5.Провести офлайн-анализ (LiveCD, rescue tools).	1.Переустановить агент защиты (Defender, ESET, CrowdStrike и др.) через автоматизированный скрипт или консоль управления. 2.Удалить вредоносные драйверы: sigverif, rmmod, devcon remove, проверка через driverquery /v или lsmod. 3. Восстановить стандартные ключи реестра/конфигурации системных служб (reg import, GPO restore). 4.Включить защитные политики: WDAC, Secure Boot, Device Guard, Kernel Patch Protection (Windows).

Продолжение таблицы 61

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE-этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
Деструктивное воздействие	Выявлено использование ресурсов системы (CPU, GPU) для скрытого майнинга. CVE-2022-41001 эксплуатирует уязвимость Windows Task Scheduler для запуска задач без ведома пользователя.	1.Проанализировать нагрузку: top, htop, perf, taskmgr, nvidia-smi. 2.Проверить планировщик задач: schtasks /query, crontab -l, Get-ScheduledTask. 3.Идентифицировать майнеры: `ps au	1. Удалить исполняемые майнеры: xmrig, cpuminer, config.json, .nohup, .xsession и скрытые каталоги (~/.config/.x). 2. Удалить задачи планировщика (schtasks /delete, crontab -r, systemd user units). 3. Перезапустить службы планировщика (systemctl restart crond, taskschd.msc). 4. Откатить сетевые настройки: удалить прокси, iptables правила, DNS-хосты, связанные с майнинг-пулами. 5. Внедрить контроль ресурсов: cgroups, nice, CPU limit policies (GPO).

ЗАКЛЮЧЕНИЕ

Выполненная выпускная квалификационная работа направлена на решение актуальной задачи — повышение защищённости автоматизированных информационных систем от кибератак класса «обнаружение хоста». В рамках исследования был предложен комплексный подход, включающий анализ угроз, оценку уязвимостей, моделирование сценариев атак и разработку регламентов реагирования.

В ходе работы:

— проведён анализ баз данных угроз и уязвимостей (CAPEC, CVE, NVD, БДУ ФСТЭК, MITRE ATT&CK), а также инструментов оценки рисков (CVSS, EPSS, OWASP). Выявлены их особенности, преимущества и применимость в контексте защиты АИС.

— определены взаимосвязи между шаблонами атак и уязвимостями. Сформированы таблицы соответствий CAPEC–CVE–MITRE, что позволило выстроить логические цепочки для построения реалистичных сценариев атак.

— разработаны микромодели атак, основанные на MITRE ATT&CK. Для каждого сценария рассчитаны вероятности успешной реализации и потенциальный ущерб, что позволило выделить наиболее критичные угрозы.

— сформирован набор организационно-правовых регламентов по реагированию на атаки класса «обнаружение хоста». В отличие от типовых инструкций, они адаптированы под особенности АИС и включают процедуры мониторинга, фильтрации и оперативного устранения инцидентов.

По итогам работы сформирована гибкая методика оценки рисков, которая может быть адаптирована под различные типы АИС и легко расширяется за счёт новых баз данных и метрик. Полученные результаты могут быть использованы как в практических целях (в подразделениях ИБ), так и в дальнейших научных исследованиях.

Таким образом, поставленная цель достигнута, а сформулированные задачи успешно решены. Предложенные решения позволяют существенно повысить уровень защищённости АИС от атак рассматриваемого класса и дают основу для дальнейшего совершенствования систем управления информационной безопасностью.

СПИСОК ЛИТЕРАТУРЫ

1 Организационно-правовая защита сетей / Г. А. Остапенко и др.; Под ред. Академика РАН Д. А. Новикова. Сер. Теория сетевых войн. Вып. 8. М.: Горячая линия Телеком, 2023.- 228 с. – Текст: непосредственный.

2 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 203-210. – Текст: непосредственный.

3 С. Пекло А.Ю. Атаки типа «сетевая разведка»: риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Осталенко // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 235-246. – Текст: непосредственный.

4 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

5 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

6 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 341-358. – Текст: непосредственный.

7 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 447-454. – Текст: непосредственный.

8 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. - Т. 26. Вып. 4. - С. 579-586. – Текст: непосредственный.

9 Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т.26.Вып. 4.- С.597-602. – Текст: непосредственный.

10 Остапенко А.Г. Направление совершенствования нормативно-правового обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин // Информация и безопасность.2022. - Т.25.Вып. 4. - С.593-598. – Текст: непосредственный.

11 ГОСТ Р ИСО/МЭК 15408-2-2013. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200105710. – Текст: электронный.

12 ГОСТ Р ИСО/МЭК 27001-2021. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200181890. – Текст: электронный.

13 ГОСТ Р 59710-2022. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200194356. – Текст: электронный.

14 ГОСТ Р 59711-2022. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200194357. – Текст: электронный.

15 ГОСТ Р 59547-2021. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200180385. – Текст: электронный.

16 Рекомендации по первоочередным мерам, направленным на обнаружение, предупреждение и ликвидацию последствий компьютерных атак. – Электрон. дан. –

Режим доступа: https://safe-surf.ru/upload/ALRT/ALRT-20220316.1.pdf. – Текст: электронный.

17 Microsoft Security. – Электрон. дан. – Режим доступа: https://www.microsoft.com/ru-ru/security/business/security-101/what-is-incident-response. – Текст: электронный.

18 DDoS-GUARD. – Электрон. дан. – Режим доступа: https://www.anti-malware.ru/reviews/DDoS_Guard. – Текст: электронный.

19 BI.ZONE. – Электрон. дан. – Режим доступа: https://bi.zone/expertise/insights/effective-counteraction-to-cyber-attacks/. – Текст: электронный.

20 Общий обзор классификаций угроз безопасности: OWASP, CWE, CAPEC, WASC. – Электрон. дан. – Режим доступа: https://safe-surf.ru/specialists/article/5210/595970/. – Текст: электронный.

21 MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

22 CAPEC. – Электрон. дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

23 Сравнительный анализ баз данных MITRE ATT&CK и CAPEC. – Электрон. дан. – Режим доступа: https://cyberleninka.ru/article/n/sravnitelnyy-analiz-baz-dannyh-mitre-att-ck-i-capec/viewer. – Текст: электронный.

24 CAPEC-285. – Электрон. дан. – Режим доступа: https://capec.mitre.org/data/definitions/285.html. – Текст: электронный.

25 CAPEC-295. – Электрон. дан. – Режим доступа: https://capec.mitre.org/data/definitions/295.html. – Текст: электронный.

26 CAPEC-294. – Электрон. дан. – Режим доступа: https://capec.mitre.org/data/definitions/294.html. – Текст: электронный.

27 CAPEC-296. – Электрон. дан. – Режим доступа: https://capec.mitre.org/data/definitions/296.html. – Текст: электронный.

28 CWE - Common Weakness Enumeration. – Электрон. дан. – Режим доступа: https://cwe.mitre.org/index.html. – Текст: электронный.

29 Банк данных угроз безопасности информации ФСТЭК России https://bdu.fstec.ru/threat.– Текст: электронный.

30 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 231-238. – Текст: непосредственный.

31 Карьера в области кибербезопасности. – Электрон. дан. – Режим доступа: https://www.securitylab.ru/analytics/536641.php. – Текст: электронный.

32 NIST NICE. – Электрон. дан. – Режим доступа: https://www.nist.gov/itl/applied-cybersecurity/nice/nice-framework-resource-center/nice-framework-current-versions. – Текст: электронный.

33 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 239-246. – Текст: непосредственный.

34 Kaspersky. – Электрон. дан. – Режим доступа: https://www.kaspersky.ru/resource-center/definitions/dns. – Текст: электронный.

35 A Guide to Spoofing Attacks and How to Prevent Them in 2024. – Электрон. дан. – Режим доступа: https://www.comparitech.com/blog/information-security/spear-phishing/ – Текст: электронный.

36 Spoofing DNS Records by Abusing DHCP DNS Dynamic Updates. – Электрон. дан. – Режим доступа: https://www.akamai.com/blog/security-research/spoofing-dns-by-abusing-dhcp. – Текст: электронный.

37 What spear phishing is (with examples) and how you can avoid it. – Электрон. дан. – Режим доступа: https://www.comparitech.com/blog/information-security/spear-phishing/. – Текст: электронный.

38 Proofpoint 2024 State of the Phish. – Электрон. дан. – Режим доступа: https://www.proofpoint.com/sites/default/files/gtd-pfpt-uk-tr-state-of-the-phish-2024-a4_final.pdf– Текст: электронный.

39 Verizon 2024 Data Breach Investigation Report. – Электрон. дан. – Режим доступа: https://www.verizon.com/business/resources/reports/dbir/2024/summary-of-findings/. – Текст: электронный.

40 Что такое фарминг и как с ним бороться. – Электрон. дан. – Режим доступа: https://www.securitylab.ru/blog/company/PandaSecurityRus/346155.php/. – Текст: электронный.

41 Что такое фарминг и как от него защититься. – Электрон. дан. – Режим доступа: https://www.kaspersky.ru/resource-center/definitions/pharming. – Текст: электронный.

42 BDU:2021-03336. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/vul/2021-03336. – Текст: электронный.

43 CVE-2020-16952. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/vul/2020-05448. – Текст: электронный.

44 CVE-2022-2663. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/vul/2023-00454. – Текст: электронный.

45 CVE-2020-7505. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/vul/2020-02722. – Текст: электронный.

46 CVE-2017-7814. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/vul/2018-00160. – Текст: электронный.

47 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 219-230.

48 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336. - Текст: непосредственный.

49 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко,

А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378. - Текст: непосредственный.

50 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400. - Текст: непосредственный.

51 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420. - Текст: непосредственный.

52 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 89-106. - Текст: непосредственный.

53 Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 115-128. - Текст: непосредственный.

54 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484. - Текст: непосредственный.

55 Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284. - Текст: непосредственный.

56 Жидков Э.И. Кибератаки вида "социальная инженерия": риск-ландшафт

векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. № 2. С. 285-298. - Текст: непосредственный.

57 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 159-178. - Текст: непосредственный.

58 Архипова К.В. Автоматизированная информационная система моделирования эпидемических процессов, порожденных саморазмножающимися и мутирующими вредоносами / К.В. Архипова, А.А. Остапенко, В.В. Сафронова, В.Ю. Остапенко, Ю.Г. Пастернак // Информация и безопасность. 2022. Т. 25. № 3. С. 349-366.

59 Остапенко Г.А. Киберполигон как проект управления информационными рисками / Г.А. Остапенко, В.И. Белоножкин, А.А. Остапенко, М.Е. Волкова // Информация и безопасность. 2023. Т. 26. № 1. С. 9-16. - Текст: непосредственный.

60 Остапенко Г.А. Разработка архитектуры киберполигона для повышения качества и результативности учебного процесса в исследовании атак на информационные системы и сети / Г.А. Остапенко, С.С. Куликов, А.В. Коноплин, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. № 1. С. 101-108. - Текст: непосредственный.

61 Остапенко А.Г. Методические основы проектной деятельности при выполнении научно-исследовательской работы студентами специалитета в сфере обеспечения информационной безопасности / А.Г. Остапенко, А.С. Пахомова, Д.А. Нархов, А.А. Остапенко, А.И. Шеншин // Информация и безопасность. 2023. Т. 26. № 2. С. 169-176. - Текст: непосредственный.

62 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта "безопасный интернет" / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын // Информация и безопасность. 2021. Т. 24. № 2. С. 287-296. - Текст: непосредственный.

63 Сердечный А.Л. Метод информационно-картографического анализа активности группировок хактивистов / А.Л. Сердечный, А.Г. Остапенко // Информация

и безопасность. 2023. Т. 26. № 4. С. 587-596. - Текст: непосредственный.

64 Остапенко А.Г. Сетевая вирусология: прогнозирование развития двувирусных эпидемических процессов в сетях. / А.Г. Остапенко, Е.В. Зарочинцев, О.А. Остапенко, К.В. Сибирко, В.В. Сафронова, П.Д. Федоров. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 203-222. - Текст: непосредственный.

65 Остапенко А.Г. Картографические модели процессов диффузии вредоно- сов в сетевом киберпространстве. / А.Г. Остапенко, А.Л. Сердечный, А.А. Остапенко, С.С. Куликов. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 281-286. - Текст: непосредственный.

66 Остапенко А.Г. Научно-технические результаты и перспективы реализации проекта «Безопасный интернет». / А.Г. Остапенко, И.А. Боков, А.А. Остапенко, Н.М. Лантюхов, Т.Ю. Мирошниченко, С.В. Лихобабин, С.Д. Трубицын. // Информация и безопасность. 2021. Т. 24. Вып. 2. С. 287-296. - Текст: непосредственный.

67 Кобцев О.Е. Сетевые атаки компьютерными вирусами: риск-ландшафт / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, В.Г. Юрасов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 55 -66. - Текст: непосредственный.

68 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частная политика и регламенты информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, Л.В. Паринова, Ю.Г. Пастернак, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 67-80. - Текст: непосредственный.

69 Кобцев О.Е. Сетевые атаки компьютерными вирусами: частные инструкции информационной безопасности / О.Е. Кобцев, А.И. Шеншин, В.М. Питолин, В.И. Белоножкин, К.А. Разинкин, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 81-90. - Текст: непосредственный.

70 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, Д.С. Покудин, Н.Н. Корвяков // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 239-246. - Текст: непосредственный.

71 Смирнов В.В. Кибератаки вида «анализ целевого объекта»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П.

Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284. - Текст: непосредственный.

72 Жидков Э.И. Кибератаки вида «социальная инженерия»: риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 285-294. - Текст: непосредственный.

73 Золотарев А.А. Сетевые атаки с помощью «сниффер -пакетов»: разработка частной политики информационной безопасности / А.А. Золотарев, Д.А. Нар- хов, А.Н. Мокроусов, В.И. Борисов, А.Е. Дешина, А.С. Пахомова, А.Ю. Егоров // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 91-98. - Текст: непосредственный.

74 Золотарев А.А. Сетевые атаки с помощью «сниффер-пакетов построение риск-ландшафта / А.А. Золотарев, Д.А.Нархов, М.И. Бочаров, А.И. Мордовин, Н.М. Радько, О.В. Поздышева, А.Г. Краснобородкин // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 99-108. - Текст: непосредственный.

75 Минаев В.А. Геофизические угрозы кибербезопасности / В.А. Минаев, А.О. Фаддеев, А.В. Мокшанцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 117-124. - Текст: непосредственный.

76 Рытов М.Ю. Порядок оценки уровня эффективности системы непрерывного противодействия инцидентам информационной безопасности на объекте / М.Ю. Рытов, О.М. Голембиовская, Е.В. Кондрашова, М.М. Голембиовский, К.Е. Шинаков // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 135-142. - Текст: непосредственный.

77 Александров А.Г. Анализ угроз информационной безопасности при использовании облачных сервисов / А.Г. Александров, А.Ю. Петухов, М.Ю. Рытов // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 143-151. - Текст: непосредственный.

78 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть I) / Д.В. Щербакова, А.Ю. Пекло,

А.С. Кривошеин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 185-196. - Текст: непосредственный.

79 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть II) / Д.В. Щербакова, А.Ю. Пекло, Д.С. Печкин, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 197-208. - Текст: непосредственный.

80 Щербакова Д.В. Организационно-правовое обеспечение сетевой контрразведывательной деятельности корпорации (часть III) / Д.В. Щербакова, А.Ю. Пекло, Ю.В. Макаров, В.М. Питолин, О.Ю. Макаров, В.Н. Кострова // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 209-218. - Текст: непосредственный.

81 Сердечный А.Л. Информационное картографирование Blockchain-транзакций киберпреступников в экосистеме TON / А.Л. Сердечный, А.О. Абрамов, Е.А. Москалева // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 257-272. - Текст: непосредственный.

82 Громов Ю.Ю. Изучение возможности виртуализации технических средств защиты объектов с применением имитационного моделирования / Ю.Ю. Громов, П.И. Карасев, Ф.М. Пыршев // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 379-388. - Текст: непосредственный.

83 Подтопельный В.В. Исследование специфики моделирования компьютерных атак с использованием марковских процессов принятий решений и Q-обучения / В.В. Подтопельный // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 421 - 440. - Текст: непосредственный.

84 Зорин В.А. Информационная безопасность и нейробиология социальной инженерии: когнитивные искажения, эмпатия / В.А. Зорин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 441-448. - Текст: непосредственный.

85 Зимницкий А.Г. Программно-технический комплекс выявления субъектов с повышенным риском девиантного поведения / А.Г. Зимницкий, А.А Остапенко // Информация и безопасность. 2022. Т. 25. № 4. С. 571 -582. - Текст: непосредственный.

86 Сердечный А.Л. Информационная карта киберконфликта "палестина-израиль" / А.Л. Сердечный, А.Г. Остапенко // Информация и безопасность. 2023. Т. 26.

№ 4. С. 519-534. - Текст: непосредственный.

87 Остапенко А.Г. Целеполагание проектной деятельности по созданию инструментария автоматизированного выявления и риск-анализа деструктивных контентов, аффилированных с персоналом корпораций / А.Г. Остапенко, И.А, Боков, С.В. Лихобабин, Д.С. Ясенко, Е.Ю. Чапурин // Информация и безопасность. 2023. Т. 26. №2 4. С. 465-494. - Текст: непосредственный.

ПРИЛОЖЕНИЕ А

Таблица А1 - Паспорт уязвимости CVE-2024-53259

Идентификатор уязвимости	CVE-2024-53259: uic-go — это реализация протокола QUIC на языке Go. Злоумышленник, не связанный с сетью, может внедрить пакет ICMP Packet Too Large. Поскольку в уязвимых версиях quic-go использовался IP_PMTUDISC_DO, ядро возвращало ошибку «слишком большое сообщение» при sendmsg, то есть когда quic-go пытался отправить пакет, размер которого превышал MTU, указанный в этом пакете ICMP. Для проведения атаки злоумышленнику необходимо как минимум знать IP-адрес и порт клиента.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	/AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения

Таблица А2 - Паспорт уязвимости CVE-2022-0742

Идентификатор уязвимости	CVE-2022-0742: Утечка памяти в реализации icmp6 в ядре Linux 5.13+ позволяет удалённому злоумышленнику вывести хост из строя, заставив его исчерпать память с помощью пакетов icmp6 типа 130 или 131.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ устранения	Обновление программного обеспечения

Таблица А3 - Паспорт уязвимости CVE-2023-20083

Идентификатор уязвимости	CVE-2023-20083 Уязвимость в проверке ICMPv6 при использовании механизма обнаружения Snort 2 в программном обеспечении Cisco Firepower Threat Defense (FTD) может позволить удалённому злоумышленнику без аутентификации загрузить процессор уязвимого устройства на 100 %, что может привести к остановке обработки всего трафика и отказу в обслуживании (DoS).
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:H/Au:N/C:C/I:C/A:C
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 8,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения

Таблица А4 - Паспорт уязвимости CVE-2021-40114

Идентификатор уязвимости	CVE-2021-40114 В нескольких продуктах Cisco обнаружена уязвимость, связанная с тем, как механизм обнаружения Snort обрабатывает ICMP-трафик. Это может позволить удалённому злоумышленнику без аутентификации вызвать отказ в обслуживании (DoS) на уязвимом устройстве.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	/AV:N/AC:H/PR:N/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 6,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения

Таблица А5 - Паспорт уязвимости CVE-2023-20051

Идентификатор уязвимости	CVE-2023-20051 Уязвимость в векторном процессоре пакетов (Vector Packet Processor, VPP) сетевого шлюза Cisco Packet Data Network Gateway (PGW) может позволить удалённому злоумышленнику без аутентификации остановить обработку ICMP-трафика через IPsec-соединение.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения

Таблица А6 - Паспорт уязвимости CVE-2023-20086

Идентификатор уязвимости	CVE-2023-20086 Уязвимость в обработке ICMPv6 в программном обеспечении Cisco Adaptive Security Appliance (ASA) и Cisco Firepower Threat Defense (FTD) может позволить удалённому злоумышленнику без аутентификации вызвать отказ в обслуживании (DoS).
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 3.1 составляет 8,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения

Таблица А7 - Паспорт уязвимости CVE-2024-36927

Идентификатор уязвимости	CVE-2024-36927 В ядре Linux устранена следующая уязвимость: ipv4: исправлен доступ к неинициализированному значению в __ip_make_skb() KMSAN сообщил о доступе к неинициализированному значению в __ip_make_skb() [1]. __ip_make_skb() проверяет HDRINCL, чтобы узнать, есть ли в skb icmphdr. Однако HDRINCL может привести к состоянию DOS
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:L/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.1 составляет 4,7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения

Таблица А8 - Паспорт уязвимости CVE-2024-56647

Идентификатор уязвимости	CVE-2024-56647 В ядре Linux устранена следующая уязвимость: net: Исправлено повторное переключение хоста icmp, вызывающее ip_rt_bug сбой arp-канала может вызвать ip_rt_bug при включенной xfrm, трассировка вызовов
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.1 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения

Таблица А9 - Паспорт уязвимости CVE-2022-49638

Идентификатор уязвимости	CVE-2022-49638 В ядре Linux устранена следующая уязвимость: icmp: исправлены гонки данных вокруг sysctl. При чтении переменных sysctl icmp они могут изменяться одновременно. Поэтому нам нужно добавить READ_ONCE(), чтобы избежать гонок данных.
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.1 составляет 4,7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения

Таблица А10 - Паспорт уязвимости CVE-2023-28981

Идентификатор уязвимости	CVE-2023-20051 Уязвимость, связанная с некорректной проверкой входных данных в ядре операционных систем Juniper Networks Junos OS и Junos OS Evolved, позволяет злоумышленнику, не прошедшему аутентификацию, вызвать отказ в обслуживании (DoS).
Идентификатор типа ошибки	CWE-200
Базовый вектор уязвимости	AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 3.1 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Не существует
Способ устранения	Обновление программного обеспечения